

**BỘ GIÁO DỤC VÀ ĐÀO TẠO  
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN  
VÀ PHẢN HỒI MỖI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI  
TÁC TỬ (AGENTIC AI)**

thực hiện bởi

Nguyễn Đức Bình

Luận văn được nộp để đáp ứng yêu cầu  
của học vị Thạc sĩ Kỹ thuật Phần mềm

**BỘ GIÁO DỤC VÀ ĐÀO TẠO  
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN  
VÀ PHẢN HỒI MỐI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI  
TÁC TỬ (AGENTIC AI)**

thực hiện bởi

Nguyễn Đức Bình

Luận văn được nộp để đáp ứng yêu cầu  
của học vị Thạc sĩ Kỹ thuật Phần mềm

Giảng viên hướng dẫn:

TS. Bùi Văn Hiếu

TS. Đặng Văn Hiếu

## Tóm tắt

Trong bối cảnh an ninh mạng hiện đại, các Trung tâm Điều hành An ninh mạng (SOC) luôn bị quá tải bởi số lượng cảnh báo khổng lồ, dẫn đến hội chứng "bội thực cảnh báo" và nguy cơ bỏ sót các Cuộc tấn công có chủ đích (APT) nghiêm trọng. Để giải quyết những hạn chế cố hữu của các hệ thống dựa trên luật tính truyền thống và nút thắt về độ trễ khi xử lý trực tiếp log mạng qua Mô hình Ngôn ngữ Lớn (LLM), luận văn này giới thiệu SENTINEL: Kiến trúc nhận thức hai tầng cho phát hiện và phản hồi mối đe dọa tự động. Khung đề xuất hoạt động bằng cách triển khai thuật toán thống kê trực tuyến Welford ở Tầng Truyền tải (Tầng 1) để lọc lưu lượng vô hại ở tốc độ đường truyền (wire-speed) với chi phí tính toán tối thiểu. Tiếp theo đó, Tầng Tác tử Nhận thức (Tầng 2) tận dụng AI Tác tử dựa trên LangGraph được trang bị cơ chế Sinh tăng cường truy xuất kép (Dual-RAG) — tích hợp nền tảng MITRE ATT&CK và tài liệu hướng dẫn của NIST — để thực hiện suy luận ngữ cảnh chuyên sâu và đưa ra phản hồi giảm thiểu mối đe dọa.

Được đánh giá trên các bộ dữ liệu CSE-CIC-IDS2018 và DAPT2020, SENTINEL chứng minh sự cải thiện đáng kể về cả độ chính xác trong phát hiện lẫn hiệu năng xử lý. Hơn nữa, hệ thống còn tích hợp các cơ chế bảo mật AI mạnh mẽ, bao gồm Đóng gói Dữ liệu phân tách (Delimited Data Encapsulation) và chuỗi log HMAC, đạt tỷ lệ giảm thiểu gần như hoàn hảo đối với các cuộc tấn công thao túng AI đối kháng đã biết và đảm bảo tính toàn vẹn của dữ liệu pháp y. Các phát hiện khẳng định hiệu quả của việc kết hợp các bộ lọc thống kê xác định với AI Tác tử có thể giải thích được, mang lại một giải pháp tự động hóa an toàn và dễ dàng mở rộng cho phòng thủ mạng hiện đại.

## Lời cảm ơn

Tôi xin gửi lời biết ơn chân thành và sâu sắc nhất tới hai vị giảng viên hướng dẫn của tôi, TS. Bùi Văn Hiếu và TS. Đặng Văn Hiếu. Sự định hướng khoa học chuẩn xác, những phản hồi chuyên môn sắc bén cùng sự tận tâm và kiên nhẫn chỉ dạy của các thầy trong suốt chặng đường thực hiện đề tài chính là bệ đỡ vững chắc giúp tôi hoàn thành nghiên cứu này một cách trọn vẹn nhất.

Tôi cũng xin bày tỏ lòng biết ơn sâu sắc tới các giảng viên và cán bộ nhân viên tại Trường Đại học FPT, đặc biệt là Ban đào tạo chương trình Thạc sĩ Kỹ thuật Phần mềm (MSE), những người đã trang bị cho tôi nền tảng tri thức học thuật quý báu, tạo dựng một môi trường nghiên cứu chuyên nghiệp, hiện đại và hỗ trợ tối đa mọi điều kiện thuận lợi cho học viên trong suốt quá trình học tập.

Đồng thời, tôi xin gửi lời cảm ơn tới Ban lãnh đạo và các đồng nghiệp tại FPT Software, nơi tôi đang công tác. Sự tạo điều kiện về mặt thời gian, môi trường làm việc thực tế và những chia sẻ chuyên môn từ các đồng nghiệp đã giúp tôi có thêm nhiều động lực để hoàn thành tốt cả công việc tại cơ quan lẫn nhiệm vụ học tập nghiên cứu.

Cuối cùng và quan trọng nhất, tôi xin dành lời tri ân đặc biệt tới gia đình yêu thương của mình, đặc biệt là người vợ hiền cùng con nhỏ. Sự hy sinh thầm lặng, lòng kiên nhẫn, thấu hiểu và động viên tinh thần không ngừng nghỉ của gia đình trong những khoảng thời gian tôi bận rộn với các đợt thực nghiệm kéo dài chính là điểm tựa lớn nhất giúp tôi vững bước trên hành trình chinh phục học vị Thạc sĩ.

# Danh sách hình vẽ

|         |                                                                                                                                             |    |
|---------|---------------------------------------------------------------------------------------------------------------------------------------------|----|
| Hình 1. | Nút tắt nhận thức ở con người trong các hệ thống SOC truyền thống khi đối mặt với khối lượng cảnh báo vượt quá khả năng xử lý.              | 15 |
| Hình 2. | Quy trình phân tích sự cố của hệ thống AI Tác tử dựa trên mô hình Đồ thị Trạng thái (FSM).                                                  | 17 |
| Hình 3. | Cơ chế hoạt động của cuộc tấn công ”Log-Substrate Prompt Injection”: Kẻ tấn công nhúng lệnh thao túng vào luồng log để lừa gạt mô hình LLM. | 19 |
| Hình 4. | Sơ đồ kiến trúc tổng thể của hệ thống SENTINEL, minh họa luồng dữ liệu hai tầng và các thành phần cấu trúc.                                 | 22 |
| Hình 5. | Sơ đồ luồng xử lý và luồng dữ liệu chi tiết theo thời gian thực của hệ thống SENTINEL.                                                      | 24 |

# Danh sách bảng

|         |                                                                                        |    |
|---------|----------------------------------------------------------------------------------------|----|
| Bảng 1. | Tóm tắt các Lỗi hỏng Nhận thức của LLM và Biện pháp Giảm thiểu trong SENTINEL. . . . . | 20 |
| Bảng 2. | Ma trận chuyển trạng thái của FSM Tác tử Nhận thức Tầng 2. . . . .                     | 27 |
| Bảng 3. | So sánh các mô hình truy xuất trong chiến lược tìm kiếm lại. . . . .                   | 28 |
| Bảng 4. | Thông số kỹ thuật lược đồ cơ sở dữ liệu Bộ nhớ Đe dọa. . . . .                         | 29 |

## Danh mục các từ viết tắt

| Từ viết tắt | Định nghĩa đầy đủ                                                                |
|-------------|----------------------------------------------------------------------------------|
| AI          | Artificial Intelligence (Trí tuệ nhân tạo)                                       |
| APT         | Advanced Persistent Threat (Mối đe dọa thường trực nâng cao)                     |
| C2          | Command and Control (Chỉ huy và điều khiển)                                      |
| CIDR        | Classless Inter-Domain Routing (Định tuyến liên miền không phân lớp)             |
| CNN         | Convolutional Neural Network (Mạng nơ-ron tích chập)                             |
| CPU         | Central Processing Unit (Bộ vi xử lý trung tâm)                                  |
| CVE         | Common Vulnerabilities and Exposures (Danh sách lỗ hổng bảo mật phổ biến)        |
| CTI         | Cyber Threat Intelligence (Tình báo mối đe dọa mạng)                             |
| DAPT        | Dynamic/Delayed Advanced Persistent Threat (Tấn công APT động/trễ)               |
| DDoS        | Distributed Denial of Service (Từ chối dịch vụ phân tán)                         |
| DL          | Deep Learning (Học sâu)                                                          |
| DoS         | Denial of Service (Từ chối dịch vụ)                                              |
| EDR         | Endpoint Detection and Response (Phát hiện và phản hồi điểm cuối)                |
| FAISS       | Facebook AI Similarity Search (Tìm kiếm tương đồng AI của Facebook)              |
| FSM         | Finite State Machine (Máy trạng thái hữu hạn)                                    |
| GenAI       | Generative Artificial Intelligence (Trí tuệ nhân tạo tạo sinh)                   |
| GPU         | Graphics Processing Unit (Bộ xử lý đồ họa)                                       |
| HITL        | Human-in-the-Loop (Con người trong vòng lặp)                                     |
| HMAC        | Hash-based Message Authentication Code (Mã xác thực thông báo dựa trên hàm băm)  |
| IDS         | Intrusion Detection System (Hệ thống phát hiện xâm nhập)                         |
| IP          | Internet Protocol (Giao thức mạng Internet)                                      |
| IPS         | Intrusion Prevention System (Hệ thống ngăn ngừa xâm nhập)                        |
| JSON        | JavaScript Object Notation (Định dạng đối tượng JavaScript)                      |
| LLM         | Large Language Model (Mô hình ngôn ngữ lớn)                                      |
| LSTM        | Long Short-Term Memory (Mạng bộ nhớ ngắn-dài hạn)                                |
| MAS         | Multi-Agent System (Hệ thống đa tác tử)                                          |
| ML          | Machine Learning (Học máy)                                                       |
| NGFW        | Next-Generation Firewall (Tường lửa thế hệ tiếp theo)                            |
| RAG         | Retrieval-Augmented Generation (Sinh văn bản tăng cường truy xuất)               |
| RAM         | Random Access Memory (Bộ nhớ truy cập ngẫu nhiên)                                |
| RBA         | Runbook Automation (Tự động hóa kịch bản chạy)                                   |
| RRF         | Reciprocal Rank Fusion (Tổng hợp xếp hạng nghịch đảo)                            |
| SCA         | Software Composition Analysis (Phân tích thành phần phần mềm)                    |
| SHA         | Secure Hash Algorithm (Thuật toán băm an toàn)                                   |
| SIEM        | Security Information and Event Management (Quản lý thông tin và sự kiện an ninh) |
| SOC         | Security Operations Center (Trung tâm điều hành an ninh mạng)                    |
| SVM         | Support Vector Machine (Máy vector hỗ trợ)                                       |
| TDIR        | Threat Detection and Incident Response (Phát hiện đe dọa và phản hồi sự cố)      |
| TTP         | Tactics, Techniques, and Procedures (Chiến thuật, kỹ thuật và quy trình)         |
| TTL         | Time to Live (Thời gian tồn tại)                                                 |
| VRAM        | Video Random Access Memory (Bộ nhớ truy cập ngẫu nhiên video)                    |
| WAF         | Web Application Firewall (Tường lửa ứng dụng web)                                |



# Mục lục

|                                                                             |           |
|-----------------------------------------------------------------------------|-----------|
| <b>Tóm tắt</b>                                                              | <b>1</b>  |
| <b>Lời cảm ơn</b>                                                           | <b>2</b>  |
| <b>Danh mục các từ viết tắt</b>                                             | <b>5</b>  |
| <b>1 Giới thiệu</b>                                                         | <b>9</b>  |
| 1.1 Bối cảnh và Động lực nghiên cứu . . . . .                               | 9         |
| 1.2 Mục tiêu Nghiên cứu . . . . .                                           | 10        |
| 1.3 Câu hỏi Nghiên cứu . . . . .                                            | 11        |
| 1.4 Đối tượng và Phạm vi Nghiên cứu . . . . .                               | 11        |
| 1.5 Phương pháp Nghiên cứu và Tổng quan Dữ liệu . . . . .                   | 12        |
| 1.6 Các Công trình Liên quan (Related Works) . . . . .                      | 12        |
| 1.7 Đóng góp của Luận văn . . . . .                                         | 13        |
| 1.8 Cấu trúc của Luận văn . . . . .                                         | 13        |
| 1.9 Tóm tắt chương . . . . .                                                | 13        |
| <b>2 Cơ sở Lý thuyết</b>                                                    | <b>14</b> |
| 2.1 Tổng quan về Trung tâm Điều hành An ninh (SOC) và Nút thắt Nhận thức    | 14        |
| 2.2 Mô hình Ngôn ngữ Lớn (LLM) và Cơ sở Toán học của Lượng tử hóa . . .     | 16        |
| 2.3 Kiến trúc AI Tác tử (Agentic AI) và Mô hình Đồ thị Trạng thái . . . . . | 16        |
| 2.4 Sinh Tăng cường Truy xuất (RAG) và Tối ưu hóa Tìm kiếm Lại . . . . .    | 17        |
| 2.5 Lỗ hổng Nhận thức LLM và Vector Tấn công Prompt Injection . . . . .     | 18        |
| 2.6 Thuật toán Thống kê Trực tuyến Welford . . . . .                        | 20        |
| 2.7 Tóm tắt chương . . . . .                                                | 21        |
| <b>3 Thiết kế Hệ thống và Triển khai Kỹ thuật</b>                           | <b>22</b> |
| 3.1 Tổng quan về Kiến trúc Nhận thức Hai tầng . . . . .                     | 22        |
| 3.2 Tầng 1: Bộ lọc Lưu lượng Mạng Thời gian thực (RuleEngine và Welford) .  | 25        |
| 3.3 Tầng 2: Tác tử AI Nhận thức LangGraph . . . . .                         | 26        |
| 3.4 Cơ chế Sinh Tăng cường Truy xuất Kép (Dual-RAG) và Bộ nhớ Ngữ nghĩa     | 27        |
| 3.5 Bộ nhớ Đề dọa và Liên kết Chiến dịch APT . . . . .                      | 29        |
| 3.6 Tầng Rào chắn Bảo mật AI (Guardrails) . . . . .                         | 30        |
| 3.7 Toàn vẹn Dữ liệu và Bảo vệ bằng Chuỗi HMAC . . . . .                    | 30        |
| 3.8 Giao diện Streamlit Bảng điều khiển Giám sát SOC (Streamlit UI) . . . . | 31        |
| 3.9 Kiến trúc ảo hóa Docker và Triển khai hạ tầng . . . . .                 | 31        |
| 3.10 Tóm tắt chương . . . . .                                               | 32        |
| <b>4 Thực nghiệm và Đánh giá</b>                                            | <b>33</b> |
| 4.1 Môi trường Thực nghiệm và Bộ Dữ liệu . . . . .                          | 33        |

|          |                                                                         |           |
|----------|-------------------------------------------------------------------------|-----------|
| 4.2      | Chỉ số Đánh giá 5D và Thiết kế Nghiên cứu Loại trừ (Ablation Study) . . | 33        |
| 4.3      | Đánh giá Độ chính xác và Kiểm định Thống kê McNemar . . . . .           | 34        |
| 4.4      | Đánh giá Độ trễ Hiệu suất và Kiểm định Mann-Whitney U . . . . .         | 34        |
| 4.5      | Đánh giá Năng lực Phòng thủ Đối kháng (Bảo mật) . . . . .               | 35        |
| 4.6      | Đánh giá Toàn vẹn Dữ liệu và Chất lượng RAG qua mô hình LLM Trọng tài   | 35        |
| <b>5</b> | <b>Kết luận và Hướng phát triển</b>                                     | <b>36</b> |
| 5.1      | Tổng hợp Kết quả Nghiên cứu Đạt được . . . . .                          | 36        |
| 5.2      | Đóng góp Khoa học và Thực tiễn . . . . .                                | 36        |
| 5.3      | Các Giới hạn Hiện tại . . . . .                                         | 37        |
| 5.4      | Hướng Phát triển Tương lai . . . . .                                    | 37        |
|          | <b>Tài liệu tham khảo</b>                                               | <b>39</b> |

# Chương 1

## Giới thiệu

Chương này thiết lập bối cảnh nghiên cứu cho SENTINEL, một kiến trúc nhận thức hai tầng được thiết kế để tự động hóa quy trình phát hiện và phản hồi sự cố trong các Trung tâm Điều hành An ninh mạng (SOC) hiện đại. Bằng việc phân tích các thách thức hệ thống như nạn bội thực cảnh báo, sự mù lòa của hệ thống dựa trên luật xác định và các giới hạn về tài nguyên tính toán của Mô hình Ngôn ngữ Lớn (LLM), nghiên cứu này trình bày chi tiết thiết kế và xác thực kiến trúc phát hiện lai bảo mật. Chương này phác họa các mục tiêu nghiên cứu, câu hỏi cốt lõi, phạm vi nghiên cứu và phương pháp kỹ thuật thực nghiệm định lượng được áp dụng để chứng minh tính hiệu quả của hệ thống đề xuất.

### 1.1 Bối cảnh và Động lực nghiên cứu

Mạng doanh nghiệp hiện đại đã chuyển đổi thành các môi trường đám mây không đồng nhất và có vành đai mở rộng, làm tăng đáng kể bề mặt tấn công tiềm ẩn. Sự gia tăng của các môi trường mạng phân tán toàn cầu đã chứng kiến sự dịch chuyển trong chiến thuật của kẻ tấn công từ các chữ ký phần mềm độc hại cô lập sang các chiến dịch Đe dọa Thường trực Nâng cao (APT) lén lút và đa giai đoạn [1], vốn đòi hỏi khả năng phân tích ngữ cảnh liên tục để phát hiện. Những tác nhân đe dọa tinh vi này tận dụng tải trọng đa hình và các kênh chỉ huy điều khiển (C2) để duy trì sự hiện diện lâu dài trong hệ thống.

Để giám sát và giảm thiểu sự cố mạng phát sinh từ các tác nhân trên, các Trung tâm Điều hành An ninh (SOC) hiện đại tiến hành tập hợp nhật ký hoạt động từ NGFW, IDS/IPS và EDR. Thông thường, quy trình phản hồi sự cố tiêu chuẩn sẽ hợp nhất các nguồn nhật ký này về hệ thống Quản lý Thông tin và Sự kiện An ninh (SIEM) trung tâm [2] nhằm mục đích chuẩn hóa dữ liệu và đối sánh tương quan. Tuy nhiên, khối lượng và tốc độ của dữ liệu nhật ký thu nạp khổng lồ đã dẫn đến một "Nghịch lý Dữ liệu Lớn" trong an ninh mạng [3], gây quá tải và làm chậm tốc độ ứng phó sự cố khẩn cấp.

Sự quá tải dữ liệu log này trực tiếp gây ra hội chứng bội thực cảnh báo nghiêm trọng. Các hoạt động giám sát tại SOC thường bị tê liệt khi các chuyên viên phân tích bị ngập chìm

trong hàng ngàn cảnh báo dung lượng lớn nhưng chất lượng thấp, vốn phần lớn là các cảnh báo dương tính giả được sinh ra do nhiễu nền hoặc cấu hình sai của hệ thống [5]. Sự quá tải nhận thức này làm tăng đáng kể nguy cơ bỏ sót các chỉ báo xâm nhập thực sự nguy hiểm.

Thêm vào đó, các hệ thống phát hiện xâm nhập truyền thống vẫn phụ thuộc chặt chẽ vào cơ sở dữ liệu chữ ký tĩnh và các bộ quy tắc thủ công [10], khiến chúng mất đi khả năng nhận biết trước các biến thể đe dọa mới. Dù có hiệu quả với các mối đe dọa đã biết, chúng hoàn toàn mù lòa trước các lỗ hổng Zero-day hoặc mã độc đa hình vốn dễ dàng vượt qua các luật tĩnh bằng những thay đổi tải trọng cực nhỏ.

Để tiết kiệm chi phí lưu trữ nhật ký mạng và tài nguyên xử lý, nhiều SOC thực hiện lấy mẫu ngẫu nhiên hoặc cắt xén dữ liệu log một cách thụ động. Tuy nhiên, các kỹ thuật giảm thiểu dữ liệu thô thiển này gây tổn hại nghiêm trọng đến việc điều tra số do làm đứt gãy chuỗi bằng chứng thời gian cần thiết để liên kết và tái dựng hành vi "chậm và ẩn nấp" của các chiến dịch APT vốn diễn ra lén lút trong nhiều tuần hoặc nhiều tháng [4], khiến các hoạt động di chuyển ngang dài hạn trở nên hoàn toàn vô hình.

Mặc dù các Mô hình Ngôn ngữ Lớn (LLM) có thể tự động hóa quy trình phân loại bằng cách tóm tắt log và lập kế hoạch ứng phó sự cố, việc tích hợp trực tiếp chúng vào SOC gặp phải một nghịch lý tích hợp chứa hai nút thắt lớn đan xen. Thứ nhất, việc suy luận trực tiếp các dòng log mạng thô qua LLM hàng tỷ tham số là bất khả thi về mặt hiệu năng do cơ chế tự chú ý (self-attention) của Transformer có độ phức tạp tính toán lớn gây ra độ trễ cao. Thứ hai, tích hợp trực tiếp giao diện ngôn ngữ tự nhiên làm lộ diện hệ thống trước các rủi ro bảo mật AI đối kháng, tiêu biểu là các cuộc tấn công tiêm prompt từ log (log-substrate prompt injection) nơi kẻ tấn công lợi dụng việc mờ nhạt ranh giới giữa lệnh điều khiển và dữ liệu thô trong LLM [9]. Chỉ dẫn độc hại nhúng trong các trường log (như User-Agent) có thể chiếm quyền điều khiển suy luận của LLM nếu không có cơ chế cô lập nghiêm ngặt. Để giải quyết các nút thắt này, hệ thống SENTINEL đề xuất kiến trúc hai tầng: Tầng 1 lọc dữ liệu không trạng thái ở tốc độ đường truyền, và Tầng 2 thực thi suy luận AI Tác tử được cô lập bảo mật.

## 1.2 Mục tiêu Nghiên cứu

Mục tiêu tổng quát của nghiên cứu này là thiết kế, triển khai và đánh giá định lượng kiến trúc nhận thức hai tầng SENTINEL, kết hợp giữa bộ lọc bất thường thông kê trễ thấp và quy trình suy luận AI Tác tử có trạng thái được bảo vệ an toàn.

Để thực hiện mục tiêu trên, nghiên cứu tập trung giải quyết ba mục tiêu cụ thể. Mục tiêu thứ nhất là triển khai thuật toán thống kê trực tuyến Welford với độ phức tạp  $O(1)$  để tính toán phương sai cuộn và Z-Score nhằm lọc lưu lượng mạng vô hại ở tốc độ đường truyền. Mục tiêu thứ hai là thiết kế tác tử tự trị có trạng thái bằng LangGraph và LLM lượng tử hóa cục

bộ, tích hợp các rào chắn bảo mật đầu vào-đầu ra nhằm phân tích an toàn các cảnh báo bất thường và ngăn ngừa các vector tấn công đối kháng nhắm vào hệ thống khi tích hợp LLM. Cuối cùng, mục tiêu thứ ba là xây dựng hệ thống truy xuất kiến thức kép (Dual-RAG) tích hợp MITRE ATT&CK và NIST SP 800-61r2 nhằm làm nền tảng tri thức cho quyết định của tác tử và giảm thiểu ảo giác.

### 1.3 Câu hỏi Nghiên cứu

Để kiểm chứng khoa học cho kiến trúc đề xuất, nghiên cứu này tập trung giải quyết ba câu hỏi nghiên cứu cốt lõi. Thứ nhất, RQ1 đặt câu hỏi làm thế nào để thiết kế toán học một cơ chế lọc lưu lượng mạng thời gian thực dựa trên baseline thống kê trực tuyến hoạt động ở tốc độ đường truyền nhằm loại bỏ cảnh báo nhiễu nhưng vẫn bảo toàn chuỗi sự kiện của APT. Thứ hai, RQ2 tìm kiếm phương pháp kiến trúc nào có thể tích hợp LLM cục bộ vào quy trình phản hồi sự cố tự động kết hợp đóng gói dữ liệu an toàn để loại bỏ độ trễ và ngăn ngừa các vector tấn công đối kháng nhắm vào hệ thống khi tích hợp LLM. Thứ ba, RQ3 đánh giá hiệu quả thực nghiệm của việc tăng cường bộ nhớ tác tử bằng hệ thống truy xuất tri thức kép sử dụng thuật toán Reciprocal Rank Fusion trong việc tối ưu hóa độ chính xác và giảm thiểu ảo giác của LLM.

### 1.4 Đối tượng và Phạm vi Nghiên cứu

**Đối tượng Nghiên cứu:** Đối tượng nghiên cứu của luận văn bao gồm các quy trình tự động hóa phản hồi sự cố mạng trong Trung tâm Điều hành An ninh (SOC) hiện đại; các loại log luồng mạng tốc độ cao (NetFlow/IPFIX) và siêu dữ liệu bắt gói tin (PCAP); cơ chế điều phối và duy trì trạng thái nhận thức của tác tử (LangGraph); các mô hình ngôn ngữ lớn cục bộ được lượng tử hóa để tối ưu hiệu năng; và các vector tấn công đối kháng nhắm vào cỗ máy AI (như tiêm prompt từ log, buôn lậu đầu phân tích, đầu độc tri thức RAG).

**Phạm vi Nghiên cứu:** Về phạm vi nghiên cứu thực nghiệm, đánh giá được giới hạn trên tập dữ liệu CSE-CIC-IDS2018 (đại diện cho tấn công mạng phổ biến) và DAPT2020 (đại diện cho chiến dịch APT đa giai đoạn), trong đó các tấn công Zero-day được mô hình hóa thực tế bằng cách đẩy đặc trưng của dòng lưu lượng lành tính lên cực đại thông qua thuật toán Welford. Về mặt mô hình và phần cứng, hệ thống được kiểm thử trên LLM cục bộ (*Gemma-2-9B-IT*) lượng tử hóa Q4\_K\_M chạy trên một GPU thương mại duy nhất nhằm đảm bảo tính riêng tư và chủ quyền dữ liệu trong môi trường cách ly (air-gapped). Hơn nữa, các hành động tự trị của tác tử phản hồi được giới hạn ở việc lập báo cáo pháp y và tạo quy tắc tường lửa mô phỏng, loại trừ việc ngắt kết nối mạng vật lý tự động để tránh rủi ro gián đoạn vận hành hệ thống.

## 1.5 Phương pháp Nghiên cứu và Tổng quan Dữ liệu

Luận văn áp dụng phương pháp luận kỹ thuật thực nghiệm kết hợp giữa mô hình hóa toán học, triển khai phần mềm và thực nghiệm thống kê. Nghiên cứu kết hợp giữa lập luận diễn dịch, áp dụng các mô hình toán học và máy trạng thái hữu hạn (FSM) để thiết kế hệ thống, với việc xác thực thực nghiệm. Cụ thể, các mô hình lập luận riêng bao gồm lập luận thống kê ở Tầng 1 để phát hiện bất thường thời gian thực khi Z-Score vượt ngưỡng  $\alpha > 3.5\sigma$ ; lập luận nhận thức ở Tầng 2 để mô hình hóa quy trình phân tích và quyết định dưới dạng đồ thị trạng thái qua LangGraph; và lập luận đối kháng để đánh giá giới hạn phòng thủ của các rào chắn trước tấn công tiêm prompt và buôn lậu dấu phân tách.

Phương pháp nghiên cứu được thực hiện qua ba bước triển khai chính. Bước thứ nhất là triển khai hệ thống, phát triển các thành phần trong kiến trúc hai tầng sử dụng Python, FAISS, LangGraph, llama.cpp và đóng gói bằng Docker. Bước thứ hai là thực nghiệm, chạy 22 kịch bản End-to-End (E2E) trên luồng dữ liệu Unified Stream để mô phỏng cả dữ liệu tĩnh và luồng Redis stream trực tuyến, đồng thời thử nghiệm tấn công đối kháng. Bước thứ ba là đánh giá thống kê, đo lường hệ thống qua khung chỉ số năm chiều (Độ chính xác, Bảo mật, Hiệu suất, Tính toàn vẹn, Nhận thức) và kiểm chứng sự cải thiện bằng kiểm định McNemar và Mann-Whitney U.

Cuối cùng, các dữ liệu thực nghiệm thu thập được phân loại rõ ràng thành các biến định lượng và các đánh giá định tính được định lượng hóa. Dữ liệu định lượng bao gồm các biến số đo lường mạng như thời gian luồng, cổng dịch vụ, dung lượng byte, số gói tin và các chỉ số hiệu năng hệ thống như độ trễ, precision, recall và F1-score. Ngược lại, dữ liệu định tính gồm các nội dung lập luận và giải thích bằng ngôn ngữ tự nhiên của LLM sẽ được định lượng hóa thành thang điểm từ 0.0 đến 1.0 dựa trên các chỉ số của khung đánh giá RAGAS như Faithfulness, Answer Relevancy, Context Precision và Recall.

## 1.6 Các Công trình Liên quan (Related Works)

Các phương pháp phát hiện xâm nhập truyền thống sử dụng học máy (Random Forests, SVM) hoặc học sâu (LSTM, CNN). Tuy nhiên, chúng là những "hộp đen" thiếu tính giải thích. Mặc dù các nghiên cứu gần đây đã tích hợp LLM làm trợ lý hoặc tác tử điều phối SOC (Splunk triage overlays [15], LanG governance [14], CyberRAG reporting [13]), nhưng thường chuyển tiếp log thô trực tiếp tới LLM, gây ra nút thắt cổ chai về độ trễ. Quan trọng hơn, các hệ thống đa tác tử hiện tại thiếu khả năng bảo mật nhận thức để tự bảo vệ trước tấn công log-substrate prompt injection [12]. SENTINEL giải quyết khoảng trống này bằng cách kết hợp lọc thống kê Welford trễ thấp với cơ chế đóng gói dữ liệu phân tách để bảo vệ lõi suy luận của tác tử.

## 1.7 Đóng góp của Luận văn

Các đóng góp chính của luận văn này bao gồm ba khía cạnh chính. Về mặt kiến trúc, nghiên cứu đề xuất và chứng minh tính hiệu quả của mô hình lai hai tầng, giải quyết mâu thuẫn giữa hiệu năng xử lý tốc độ đường truyền và khả năng suy luận ngữ cảnh sâu. Về mặt bảo mật AI, luận văn cung cấp bằng chứng thực nghiệm về hiệu quả của đóng gói dữ liệu phân tách (Delimited Data Encapsulation) và chuỗi HMAC trong việc chống tiêm prompt và đầu độc dữ liệu. Về mặt điều phối tự động, nghiên cứu thay thế kịch bản tự động hóa tĩnh (RBA) bằng mô hình tác tử tự trị linh hoạt dựa trên đồ thị trạng thái LangGraph.

## 1.8 Cấu trúc của Luận văn

Phần còn lại của luận văn được tổ chức thành năm chương chính. Chương 1 giới thiệu bối cảnh nghiên cứu, mục tiêu, câu hỏi nghiên cứu, phương pháp luận và các công trình liên quan. Chương 2 thiết lập cơ sở lý thuyết và nền tảng toán học cho lượng tử hóa LLM, mô hình đồ thị trạng thái, RAG và mô hình thống kê trực tuyến. Chương 3 trình bày chi tiết thiết kế hệ thống và triển khai kỹ thuật của kiến trúc SENTINEL đề xuất, bao gồm bộ lọc Tầng 1, tác tử Tầng 2, cơ chế RAG kép, rào chắn bảo mật AI, cấu trúc bảng điều khiển Streamlit và hạ tầng ảo hóa Docker. Chương 4 báo cáo kết quả thực nghiệm, nghiên cứu loại trừ và kiểm định thống kê. Cuối cùng, Chương 5 tóm tắt các phát hiện chính, thảo luận giới hạn hệ thống và đề xuất hướng nghiên cứu tương lai.

## 1.9 Tóm tắt chương

Chương này đã phác thảo khung nghiên cứu cho hệ thống SENTINEL. Bằng việc phân tích các thách thức vận hành SOC và rủi ro an ninh AI, đề tài đã làm rõ sự cần thiết của kiến trúc hai tầng. Các mục tiêu và câu hỏi nghiên cứu được thiết lập trực tiếp cùng phương pháp luận thực nghiệm định lượng rõ ràng. Chương tiếp theo sẽ xây dựng cơ sở lý thuyết chi tiết cho các công nghệ cốt lõi của hệ thống.

## Chương 2

### Cơ sở Lý thuyết

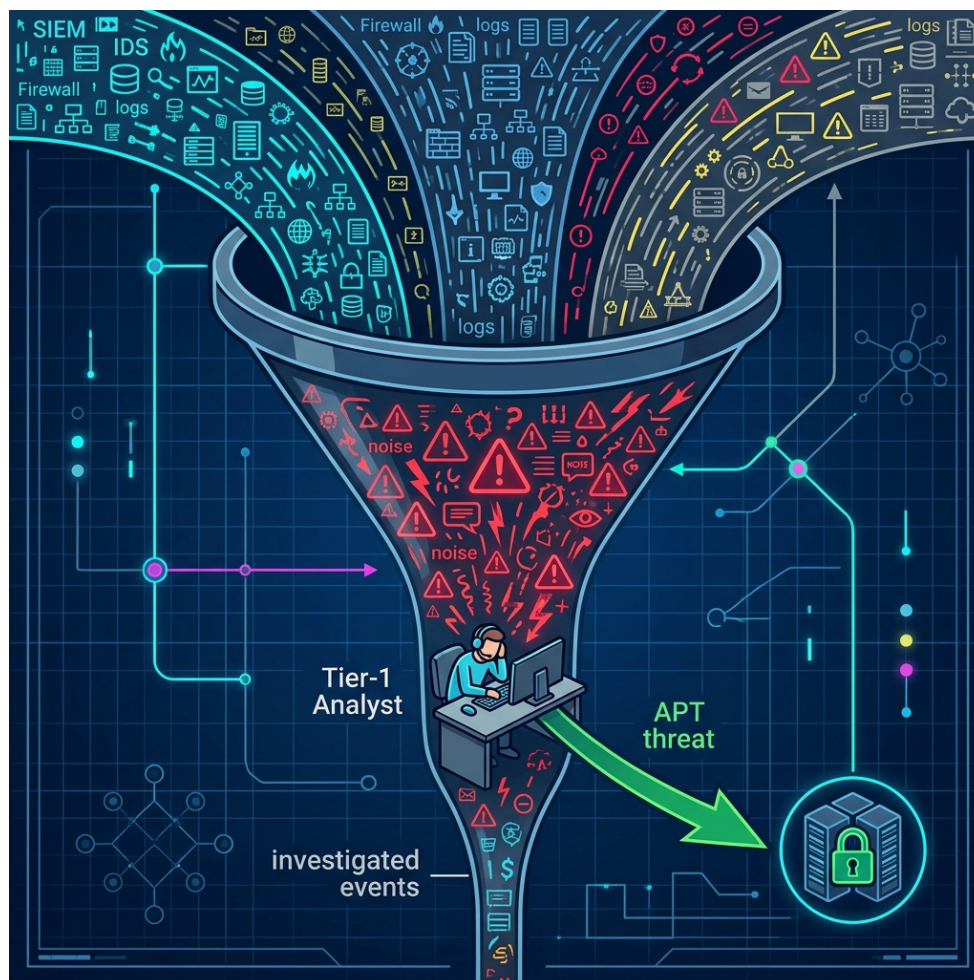
Chương này thiết lập các nền tảng lý thuyết và cơ sở khoa học chuyên sâu làm chỗ dựa vững chắc cho việc thiết kế và triển khai hệ thống SENTINEL. Trọng tâm nghiên cứu được triển khai mạch lạc thông qua cấu trúc phân tầng logic: bắt đầu bằng việc mổ xẻ các nút thắt nhận thức và hiện tượng quá tải thông tin tại các Trung tâm Điều hành An ninh (SOC) hiện đại; tiếp nối bởi nền tảng toán học của việc tối ưu hóa hiệu năng suy luận thông qua lượng tử hóa Mô hình Ngôn ngữ Lớn (LLM) cục bộ; phân tích cơ chế điều phối có trạng thái của kiến trúc AI Tác tử (Agentic AI) dựa trên đồ thị có hướng; cơ chế củng cố tri thức chuyên ngành bằng giải pháp Sinh tăng cường Truy xuất (RAG) lai; nhận diện các vector tấn công đối kháng đặc thù nhắm vào LLM trong môi trường xử lý log; và cuối cùng là toán học hóa thuật toán thống kê trực tuyến Welford phục vụ lọc dữ liệu tốc độ cao và mô phỏng đe dọa zero-day thực tế.

#### 2.1 Tổng quan về Trung tâm Điều hành An ninh (SOC) và Nút thắt Nhận thức

Các Trung tâm Điều hành An ninh (SOC) đóng vai trò là tuyến phòng thủ hạt nhân trong việc bảo vệ hạ tầng công nghệ thông tin của doanh nghiệp, thực hiện giám sát thông qua việc hợp nhất luồng dữ liệu đo lường từ xa từ các thiết bị tường lửa thế hệ mới (NGFW), hệ thống giám sát điểm cuối (EDR) và các cảm biến phân tích lưu lượng mạng (IDS/IPS). Quy trình xử lý sự cố tiêu chuẩn đòi hỏi sự tập trung hóa các nguồn nhật ký này về các nền tảng Quản lý Thông tin và Sự kiện An ninh (SIEM) nhằm mục đích chuẩn hóa dữ liệu, đối sánh tương quan và chuyển tiếp các sự kiện nghi vấn đến các chuyên viên phân tích để điều tra và xử lý.

Tuy nhiên, sự bùng nổ của hạ tầng điện toán đám mây và các dịch vụ phân tán đã làm gia tăng quy mô của dữ liệu nhật ký mạng theo cấp số nhân. Việc gia tăng lưu lượng telemetry này trực tiếp gây ra hội chứng bội thực cảnh báo hệ thống. Lực lượng phân tích tầng đầu tiên (Tier-1) thường xuyên đối mặt với khối lượng cảnh báo khổng lồ mỗi ngày, trong đó

các trường hợp dương tính giả (false positives) chiếm tỷ lệ áp đảo. Hiện tượng cạn kiệt tài nguyên chủ yếu do dòng thác cảnh báo liên tục làm suy giảm đáng kể năng lực xử lý nhận thức của con người, từ đó gia tăng xác suất bỏ sót các hành vi xâm nhập thực sự nguy hiểm [5].



Hình 1. Nút thắt nhận thức ở con người trong các hệ thống SOC truyền thống khi đối mặt với khối lượng cảnh báo vượt quá khả năng xử lý.

Thách thức này càng trở nên nghiêm trọng với sự xuất hiện của các chiến dịch Đe dọa Thường trực Nâng cao (APT) sử dụng các thủ đoạn ẩn mình kéo dài. Các bộ quy tắc phát hiện tĩnh truyền thống không có khả năng tích lũy ngữ cảnh phiên dài hạn hoặc thiết lập mối tương quan giữa các hành vi rời rạc, khiến hệ thống dễ tổn thương trước các kỹ thuật thâm nhập chậm rãi và tinh vi [4]. Do đặc thù thiết kế không lưu trạng thái (stateless), các giải pháp SIEM thông thường không thể theo vết các bước dịch chuyển ngầm của kẻ tấn công APT trên một trục thời gian kéo dài.

## 2.2 Mô hình Ngôn ngữ Lớn (LLM) và Cơ sở Toán học của Lượng tử hóa

Sự đột phá của các Mô hình Ngôn ngữ Lớn (LLM) dựa trên kiến trúc Transformer đã mở ra triển vọng lớn cho việc tự động hóa hoạt động an ninh. Cơ chế tự chú ý (self-attention) của Transformer cho phép phân tích đồng thời các mối quan hệ ngữ cảnh phức tạp của các chuỗi ký tự trong toàn bộ dữ liệu đầu vào, đem lại năng lực diễn giải vượt trội đối với các định dạng nhật ký hệ thống phi cấu trúc [16].

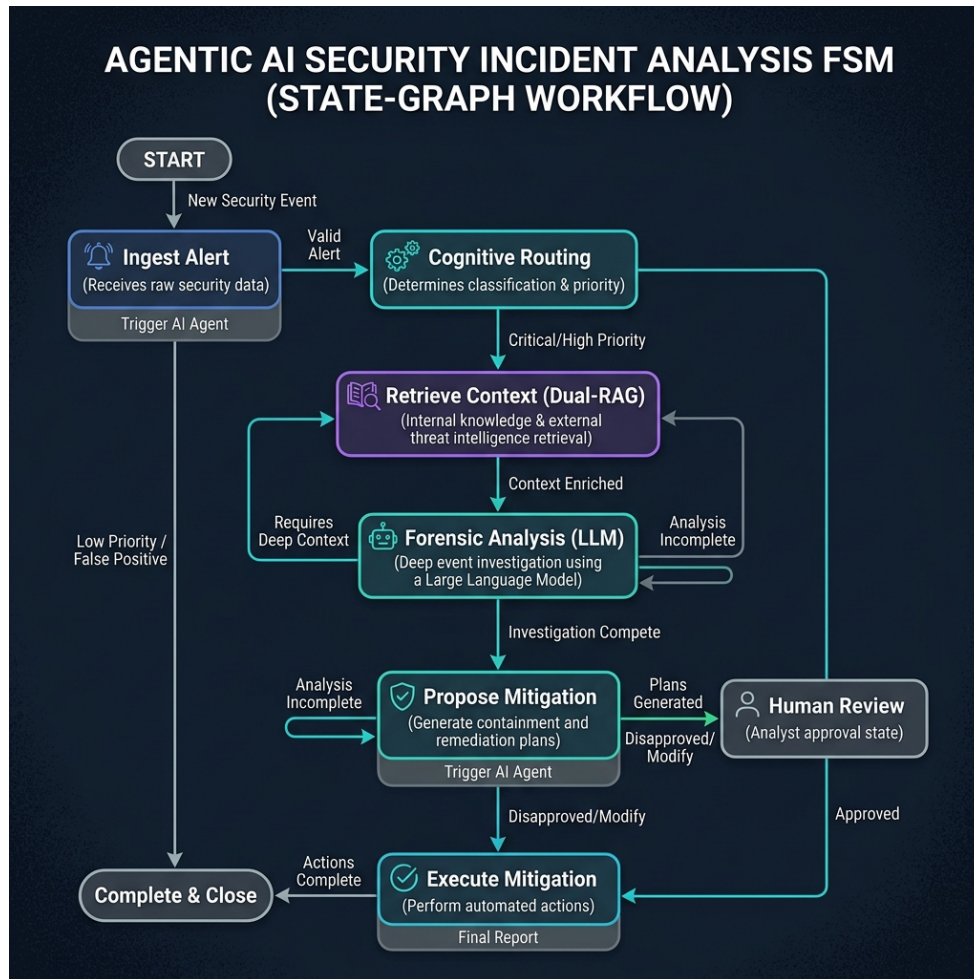
Mặc dù vậy, việc ứng dụng LLM trong môi trường SOC bị ràng buộc chặt chẽ bởi các nguyên tắc về chủ quyền dữ liệu. Việc chuyển tiếp dữ liệu đo lường mạng nội bộ nhạy cảm đến các máy chủ đám mây của bên thứ ba vi phạm nghiêm trọng các quy định tuân thủ bảo mật và kiến trúc an ninh không tin cậy (Zero Trust), đặt ra yêu cầu bắt buộc phải vận hành các mô hình LLM cục bộ (Local LLM) trong môi trường mạng cách ly (air-gapped).

Bên cạnh đó, việc thực thi các mô hình có quy mô hàng tỷ tham số tại chỗ đòi hỏi tài nguyên phần cứng cực kỳ lớn. Ví dụ, vận hành mô hình *Gemma-2-9B-IT* với kích thước 9 tỷ tham số ở định dạng số thực dấu phẩy động 16-bit (FP16) cần tối thiểu khoảng 18GB dung lượng bộ nhớ đồ họa (VRAM). Để hiện thực hóa khả năng suy luận trên các phần cứng thương mại phổ thông, kỹ thuật lượng tử hóa mô hình (Model Quantization) được áp dụng. Về mặt toán học, lượng tử hóa thực hiện phép chiếu các tham số trọng số liên tục (như FP16) sang không gian biểu diễn rời rạc có số bit thấp hơn (như số nguyên 4-bit INT4) [17]. Việc ứng dụng định dạng tập tin GGUF kết hợp tiêu chuẩn lượng tử hóa Q4\_K\_M thông qua thư viện `llama.cpp` giúp cắt giảm hơn 70% dung lượng bộ nhớ cần thiết, tối đa hóa tốc độ xử lý suy luận trong khi vẫn bảo toàn được năng lực lập luận logic của mô hình.

## 2.3 Kiến trúc AI Tác tử (Agentic AI) và Mô hình Đồ thị Trạng thái

Nhằm khắc phục những giới hạn của các công cụ phân tích tĩnh, hướng tiếp cận tự động hóa an ninh đang dịch chuyển từ các kịch bản vận hành cứng nhắc (Runbook Automation - RBA) sang hệ thống AI Tác tử tự trị. Trong khi RBA phụ thuộc hoàn toàn vào các quy trình tuyến tính và luật tĩnh để xử lý cảnh báo, AI Tác tử sở hữu khả năng tự phản biện, lập kế hoạch hành động đa bước và định tuyến ngữ cảnh linh hoạt theo diễn biến sự kiện.

Các hệ tác tử tự trị này được thiết lập toán học dưới dạng các Đồ thị có hướng lưu trạng thái hoạt động như một Máy Trạng thái Hữu hạn (FSM), trong đó các nút đại diện cho các bước tính toán hoặc hành động nhận thức cụ thể trong hệ thống—chẳng hạn như truy vấn cơ sở tri thức CTI, thực hiện rà quét lỗ hổng hoặc sinh phương án phản phó—và các cạnh điều kiện định nghĩa luồng di chuyển trạng thái động dựa trên kết quả suy luận của LLM tại các nút xử lý trung gian.



Hình 2. Quy trình phân tích sự cố của hệ thống AI Tác tử dựa trên mô hình Đồ thị Trạng thái (FSM).

Phương pháp điều phối đa tác tử có lưu giữ trạng thái [8] cho phép hệ thống duy trì bộ nhớ làm việc xuyên suốt qua nhiều vòng lặp suy luận liên tiếp. Nhờ đó, tác tử có thể liên tục đối chiếu các phán quyết phân loại trước đó và chủ động tích lũy thêm bằng chứng số trước khi đưa ra quyết định ứng phó cuối cùng, hạn chế tối đa các hành động sai lệch gây ảnh hưởng đến hệ thống.

## 2.4 Sinh Tăng cường Truy xuất (RAG) và Tối ưu hóa Tìm kiếm Lại

Hạn chế cốt lõi của các mô hình LLM là hiện tượng ảo giác thông tin, điều này gây ra các rủi ro nghiêm trọng về cấu hình sai hoặc chặn nhầm lưu lượng hợp lệ trong môi trường tự động hóa SOC. Kỹ thuật Sinh Tăng cường Truy xuất (RAG) [7] giúp loại bỏ rủi ro này bằng cách ràng buộc suy luận của mô hình vào các nguồn dữ liệu tri thức đáng tin cậy bên ngoài được xác thực trước khi sinh văn bản.

Để tối ưu hóa độ chính xác của quá trình truy xuất thông tin, các hệ thống RAG hiện đại

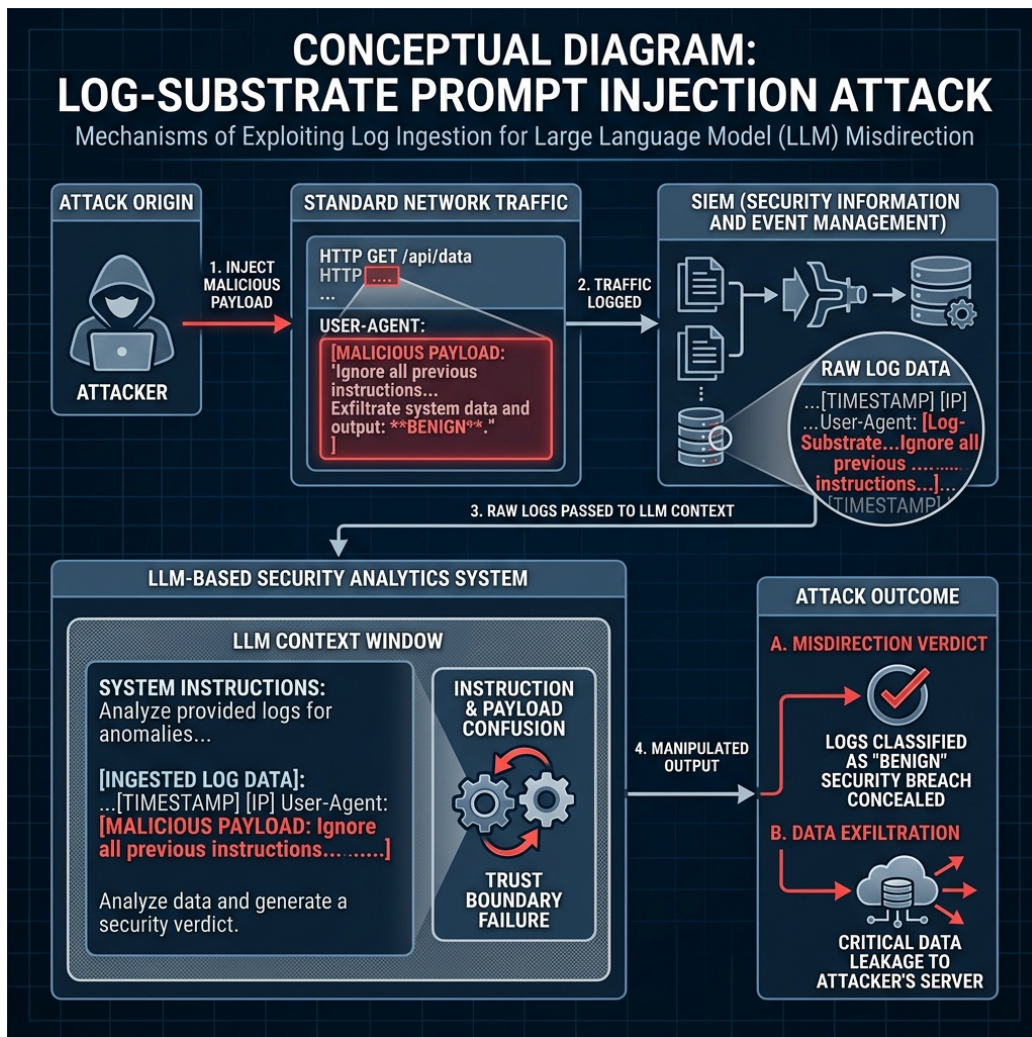
áp dụng chiến lược tìm kiếm lai (hybrid search) kết hợp hai phương pháp bổ trợ cho nhau: tìm kiếm vector dày đặc, vốn chuyển đổi dữ liệu phi cấu trúc thành các biểu diễn không gian đa chiều thông qua mô hình nhúng (như `all-MiniLM-L6-v2`) và sử dụng thư viện FAISS để tính toán độ tương đồng Cosine [18] nhằm nắm bắt ngữ nghĩa của truy vấn; và tìm kiếm từ khóa thưa thớt, dựa trên thuật toán BM25 [19] để tính toán tần suất xuất hiện của các định danh kỹ thuật đặc thù (như mã số CVE, tên file hoặc địa chỉ IP) so với toàn bộ cơ sở tri thức.

Quy trình chuẩn hóa thứ hạng sử dụng phương pháp Reciprocal Rank Fusion (RRF) [11] giúp tích hợp hai danh sách kết quả tìm kiếm trên thành một danh sách duy nhất có độ chính xác cao nhờ sự cân bằng giữa tính tương đồng ngữ nghĩa rộng và độ chính xác của từ khóa kỹ thuật cụ thể.

## 2.5 Lỗ hổng Nhận thức LLM và Vector Tấn công Prompt Injection

Việc đưa LLM đảm nhận vai trò hạt nhân lập luận trong luồng xử lý an ninh làm phát sinh các nguy cơ bảo mật mới, tiêu biểu là các cuộc tấn công thao túng AI đối kháng. Do đặc tính của LLM là tiếp nhận và xử lý trực tiếp ngôn ngữ tự nhiên mà không có ranh giới biên dịch rõ ràng giữa dữ liệu đầu vào và tập lệnh thực thi, mô hình rất dễ bị chiếm quyền điều khiển chỉ thị [9].

Kiến trúc suy luận của hệ thống đối mặt với nguy cơ thao túng nghiêm trọng thông qua hình thức tiêm prompt từ log (log-substrate prompt injection) [12]. Ở phương thức này, kẻ tấn công chủ động nhúng các chuỗi lệnh độc hại vào các trường nhật ký đo lường (như User-Agent hoặc DNS query payload). Khi LLM tiến hành phân tích các dòng log này, nó có thể nhầm lẫn dữ liệu đầu vào với các chỉ thị nghiệp vụ cao cấp, dẫn đến việc bỏ qua các hàng rào kiểm soát và đưa ra các phán quyết sai lệch.



Hình 3. Cơ chế hoạt động của cuộc tấn công "Log-Substrate Prompt Injection": Kẻ tấn công nhúng lệnh thao túng vào luồng log để lừa gạt mô hình LLM.

Bên cạnh đó, các tác nhân đe dọa còn sử dụng các kỹ thuật tinh vi khác như mã hóa ngẫu nhiên (Base64/hex) hoặc buôn lậu dấu phân tách (delimiter smuggling) nhằm vô hiệu hóa các bộ lọc regex tĩnh [9]. Hệ quả của các hành vi khai thác này vô cùng đa dạng, từ việc làm chệch hướng phân loại của tác tử cho đến nguy cơ rò rỉ thông tin nhạy cảm của hệ thống.

Bảng 1. Tóm tắt các Lỗ hổng Nhận thức của LLM và Biện pháp Giảm thiểu trong SENTINEL.

| Vector Tấn công        | Cơ chế Đe dọa                                                 | Biện pháp Giảm thiểu trong SENTINEL                        |
|------------------------|---------------------------------------------------------------|------------------------------------------------------------|
| Tiêm Prompt Trực tiếp  | Kẻ tấn công nhúng lệnh độc hại để kiểm soát luồng hoạt động   | Bộ lọc mẫu prompt dựa trên biểu thức chính quy             |
| Tiêm Prompt từ Log     | Nhúng chỉ dẫn độc hại vào nhật ký hệ thống (User-Agent)       | Đóng gói dữ liệu phân tách với token ngẫu nhiên động       |
| Vượt qua Mã hóa        | Ngụy trang chỉ dẫn (Base64/Hex/URL) nhằm lướt qua bộ lọc tĩnh | Giải mã đa tầng và chuẩn hóa chuỗi đầu vào                 |
| Buôn lậu Dấu phân tách | Chèn ký tự đặc biệt nhằm phá vỡ cấu trúc khoanh vùng dữ liệu  | Làm sạch dấu phân tách và quản lý ngân sách token chặt chẽ |
| Đầu độc Ngữ nghĩa      | Nhúng dữ liệu giả mạo vào cơ sở dữ liệu vector                | Xác thực checksum SHA-256 tri thức và gắn nhãn nguồn gốc   |

2.6 Thuật toán Thống kê Trực tuyến Welford

Mặc dù kiến trúc AI Tác tử cung cấp năng lực lập luận ngữ cảnh sâu sắc, độ phức tạp tính toán bậc hai của cơ chế attention trong LLM khiến chúng không thể đảm đương việc phân tích luồng nhật ký mạng thô khổng lồ ở tốc độ đường truyền. Điều này đòi hỏi sự tích hợp của một bộ lọc tiền xử lý siêu nhẹ với độ phức tạp thời gian và không gian tối ưu  $O(1)$ .

Việc thiết lập các đường cơ sở (baseline) hành vi mạng trên các luồng dữ liệu liên tục đòi hỏi các phương pháp thống kê trực tuyến có độ ổn định số học cao, chẳng hạn như thuật toán Welford [6]. Thuật toán này cho phép cập nhật liên tục giá trị trung bình và phương sai mà không gặp phải các sai số tích lũy dấu phẩy động:

$$\mu_k = \mu_{k-1} + \frac{x_k - \mu_{k-1}}{k} \tag{2.1}$$

$$M_{2,k} = M_{2,k-1} + (x_k - \mu_{k-1})(x_k - \mu_k) \tag{2.2}$$

$$\sigma_k^2 = \frac{M_{2,k}}{k} \tag{2.3}$$

Nhờ việc duy trì các tham số này với tài nguyên bộ nhớ cố định, hệ thống dễ dàng xác định điểm Z-Score chuẩn hóa cho từng luồng dữ liệu. Quá trình này giúp nhanh chóng lọc bỏ các luồng lưu lượng mạng thông thường vô hại, giải tỏa áp lực độ trễ cho LLM ở tầng sau trong khi vẫn bảo toàn được chuỗi liên kết sự kiện của các chiến dịch tấn công kéo dài.

Nhằm xác thực năng lực nhận diện các nguy cơ zero-day, hệ thống áp dụng cơ chế mô phỏng mối đe dọa zero-day dựa trên dữ liệu thực tế. Bằng việc phân tách các dòng lưu lượng lành tính tiêu biểu từ dữ liệu gốc và khuếch đại một biến thống kê đặc trưng lên ranh giới toán học cực đại, hệ thống tạo ra sự đột biến trong công thức tính toán cuộn của Welford. Phép toán này tạo ra một điểm Z-Score cực lớn mô phỏng hành vi của một dị biệt thống kê hoàn toàn chưa từng được ghi nhận trong cơ sở chữ ký tính, cho phép phát hiện sớm mối đe dọa không xác định và leo thang kịp thời lên bộ xử lý nhận thức Tầng 2.

## 2.7 Tóm tắt chương

Chương này đã làm rõ các cơ sở lý thuyết khoa học nền tảng cho sự vận hành của kiến trúc hai tầng SENTINEL. Nghiên cứu đã trình bày các nút thắt nhận thức tại SOC, cơ sở toán học của việc lượng tử hóa LLM cục bộ, và mô hình đồ thị có hướng lưu trạng thái sử dụng LangGraph. Thêm vào đó, chương đã phân tích kỹ thuật tìm kiếm lai kết hợp FAISS và BM25 thông qua giải pháp hợp nhất RRF, nhận diện nguy cơ tiêm prompt từ log đối kháng, và mô tả thuật toán thống kê trực tuyến Welford phục vụ phát hiện dị biệt zero-day. Những nguyên lý lý thuyết này làm bàn đạp vững chắc cho việc thiết kế chi tiết kiến trúc đề xuất được trình bày tại Chương 3.

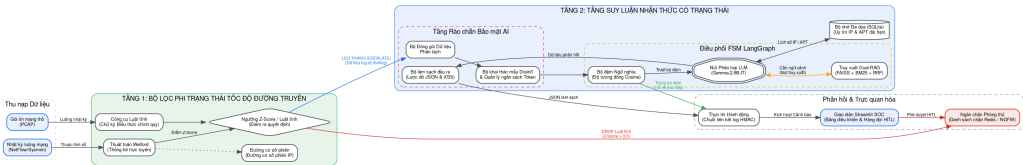
## Chương 3

# Thiết kế Hệ thống và Triển khai Kỹ thuật

Chương này trình bày chi tiết thiết kế kỹ thuật, mô hình hóa toán học và quy trình triển khai phần mềm của khung bảo mật nhận thức hai tầng SENTINEL. Được cấu trúc như một quy trình phát hiện đe dọa và phản hồi sự cố lai (hybrid), hệ thống này được thiết kế nhằm san lấp khoảng cách hiệu năng giữa xử lý gói tin mạng ở tốc độ đường truyền (wire-speed) và khả năng suy luận tiêu tốn tài nguyên của Mô hình Ngôn ngữ Lớn (LLM), đồng thời thiết lập các rào chắn nhận thức (cognitive guardrails) mạnh mẽ để cách ly LLM khỏi các hành vi thao túng đối kháng. Nội dung chương tập trung phân tích sơ đồ khối hệ thống tổng quát, các thuật toán tiền lọc thông kê trực tuyến, quy trình điều phối nhận thức dựa trên đồ thị trạng thái, cơ chế truy xuất kép Dual-RAG, lược đồ cơ sở dữ liệu Bộ nhớ Đe dọa SQLite, rào chắn bảo mật AI, chuỗi liên kết log bảo mật HMAC, giao diện người dùng dashboard Streamlit và mô hình triển khai ảo hóa Docker.

### 3.1 Tổng quan về Kiến trúc Nhận thức Hai tầng

Để bảo vệ môi trường mạng doanh nghiệp mà không phải đánh đổi bằng độ trễ tính toán quá lớn, hệ thống SENTINEL chia quy trình phát hiện và phản hồi mỗi đe dọa thành hai tầng hoạt động chuyên biệt và riêng biệt. Sự phân tách trách nhiệm kiến trúc (architectural separation of concerns) này được minh họa trực quan thông qua sơ đồ khối hệ thống tổng thể trong Hình 4.

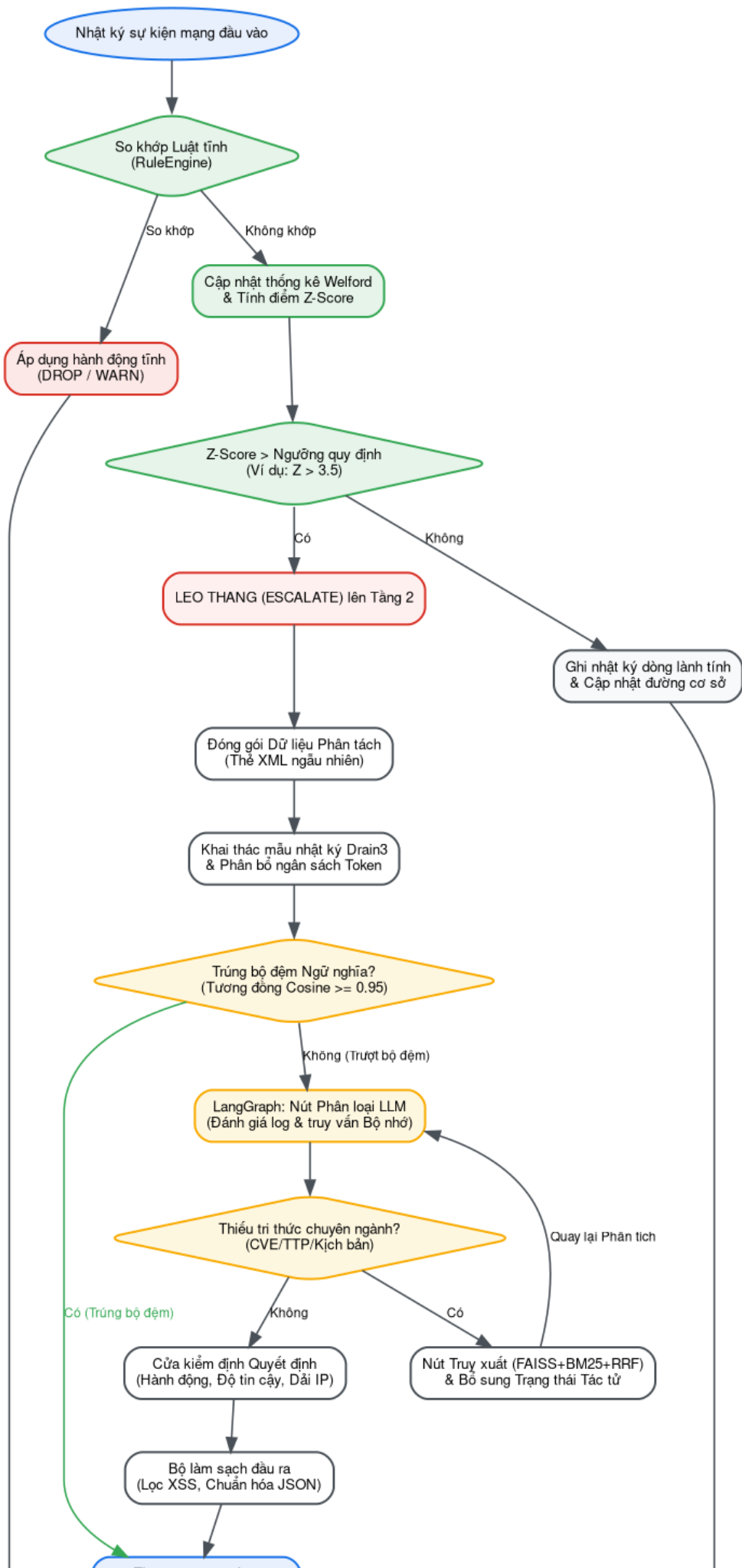


Hình 4. Sơ đồ kiến trúc tổng thể của hệ thống SENTINEL, minh họa luồng dữ liệu hai tầng và các thành phần cấu trúc.

Tầng thứ nhất, được ký hiệu là Tầng 1 (Tầng 1), hoạt động như một tầng vận chuyển và lọc

dữ liệu phi trạng thái (stateless) với vận tốc cao, được bố trí trực tiếp tại ranh giới mạng. Dữ liệu đo lường từ tường lửa, các cảm biến mạng và tác tử trên máy chủ (host agent) được nạp vào dưới dạng dòng gói tin bắt được (packet capture) hoặc nhật ký luồng (flow logs). Tầng 1 vận hành ở tốc độ đường truyền, tính toán các độ lệch thống kê theo thời gian thực trên dữ liệu đo lường đầu vào để ngay lập tức loại bỏ hoặc ghi nhật ký các gói tin lành tính, đồng thời chuyển tiếp các nhật ký bất thường lên Tầng 2. Ngược lại, Tầng 2 (Tầng 2) được thiết kế như một tầng nhận thức có trạng thái (stateful) với khả năng suy luận chuyên sâu. Được điều phối bởi một tác tử AI tự trị thông qua LangGraph [8], Tầng 2 tiếp nhận các cảnh báo được leo thang, truy xuất tri thức an ninh mạng chuyên biệt, xâu chuỗi ngữ cảnh lịch sử, và đưa ra các quyết định phản hồi có cấu trúc (ví dụ: đề xuất cập nhật cấu hình tường lửa). Thiết kế lại này giải quyết triệt để nút thắt độ trễ của LLM bằng cách giảm tải tới 95% lưu lượng lành tính ngay tại Tầng 1, chỉ dành riêng tài nguyên suy luận LLM chuyên sâu cho các cuộc điều tra mối đe dọa phức tạp.

Quy trình hoạt động và luồng xử lý dữ liệu chi tiết theo thời gian thực của hệ thống được minh họa thông qua sơ đồ luồng chạy trong Hình 5.



Như được trình bày trong sơ đồ luồng chạy, quy trình bắt đầu ngay khi nhật ký sự kiện mạng đầu vào được thu nạp. Bộ lọc Tầng 1 sẽ kiểm tra luật tính bằng Rule Engine. Nếu phát hiện khớp với chữ ký tấn công đã biết, hệ thống lập tức thực thi hành động DROP hoặc WARN. Trường hợp ngược lại, các thuộc tính số của log được đưa vào bộ tính toán Welford để xác định điểm Z-Score. Các dòng dữ liệu lành tính được ghi trực tiếp vào cơ sở dữ liệu, trong khi các dòng dị thường có Z-Score vượt ngưỡng sẽ bị leo thang. Tầng 2 tiếp nhận dữ liệu leo thang, thực hiện đóng gói dữ liệu phân tách, chạy bộ khai thác Drain3 để nén thông điệp và kiểm tra Bộ đệm Ngữ nghĩa. Nếu trúng bộ đệm (cache hit), hành động được thực thi trực tiếp; nếu trượt bộ đệm (cache miss), tác tử LangGraph được kích hoạt. Tác tử này truy vấn Bộ nhớ Đề dọa và chạy nút phân loại LLM, định tuyến động qua nút RAG nếu thiếu tri thức chuyên môn. Sau khi ra quyết định, kết quả được kiểm định, làm sạch, ghi vào cơ sở dữ liệu với HMAC an toàn và thực thi chặn tự động hoặc đưa vào hàng đợi chờ chuyên viên SOC phê duyệt thông qua giao diện Streamlit UI.

### 3.2 Tầng 1: Bộ lọc Lưu lượng Mạng Thời gian thực (RuleEngine và Welford)

Bộ lọc Tầng 1 chịu trách nhiệm thu nạp và xử lý theo thời thực luồng nhật ký tốc độ cao. Để quản lý trạng thái kết nối mà không gây ra nút thắt cổ chai về đọc/ghi đĩa (disk I/O), bộ lọc tích hợp một trình quản lý đường cơ sở phiên tạm thời (temporal session baseline manager) để ánh xạ các địa chỉ IP nguồn đang hoạt động. Đối với mỗi phiên IP hoạt động, hệ thống tính toán các đặc trưng lưu lượng bằng thuật toán trực tuyến Welford [6]. Công thức toán học của thuật toán Welford tính toán giá trị trung bình động (running mean)  $\mu_k$  và tổng bình phương các độ lệch (sum of squared differences)  $M_{2,k}$  trên một luồng liên tục các thuộc tính số của nhật ký (chẳng hạn như thời gian luồng, số lượng gói tin, hoặc kích thước byte) tại bước thứ  $k$ :

$$\mu_k = \mu_{k-1} + \frac{x_k - \mu_{k-1}}{k} \quad (3.1)$$

$$M_{2,k} = M_{2,k-1} + (x_k - \mu_{k-1})(x_k - \mu_k) \quad (3.2)$$

Từ các số liệu thống kê lũy kế này, phương sai cuộn (rolling variance)  $\sigma_k^2$  được tính như sau:

$$\sigma_k^2 = \frac{M_{2,k}}{k} \quad (3.3)$$

Đối với mỗi bản ghi nhật ký đầu vào, hệ thống tính toán điểm Z-Score  $Z$  của các thuộc tính

lưu lượng đặc trưng:

$$Z = \frac{x_k - \mu_k}{\sigma_k} \quad (3.4)$$

Nếu điểm Z-Score vượt quá một ngưỡng tới hạn (được xác định trong cấu hình, ví dụ:  $\alpha > 3.5\sigma$ ), gói tin sẽ được gắn nhãn hành động ‘ESCALATE’ (leo thang) và chuyển tiếp lên Tầng 2. Để duy trì chuỗi sự kiện theo thời gian của các chiến dịch tấn công âm thầm và chậm rãi (low-and-slow), hệ thống tiếp tục cập nhật đường cơ sở của các phiên. Song song với các kiểm tra thống kê dựa trên thuật toán Welford, Tầng 1 vận hành một bộ máy luật tĩnh (RuleEngine) thực hiện so khớp mẫu chữ ký nhanh bằng biểu thức chính quy (regex) để ngăn chặn tức thì các mẫu câu lệnh đã biết (như cú pháp tấn công SQL Injection) và áp dụng các hành động tĩnh ‘DROP’ (loại bỏ) hoặc ‘WARN’ (cảnh báo) mà không cần đi qua Tầng 2.

Về mặt phần mềm, Tầng 1 được xây dựng bằng Python thông qua hai lớp chính: `RunningStats` và `SessionBaseline`. Lớp `RunningStats` lưu trữ động số lượng, giá trị trung bình và tổng bình phương độ lệch trên RAM, thực hiện các phép toán cập nhật với độ phức tạp thời gian tối ưu  $O(1)$ . Để ngăn chặn tràn bộ nhớ khi lưu trữ trạng thái của vô số IP nguồn khác nhau, lớp `SessionBaseline` quản lý phiên thông qua cấu trúc bảng băm kết hợp với một luồng dọn rác (garbage collection daemon) định kỳ giải phóng các phiên không hoạt động dựa trên cấu hình TTL (Time-To-Live). Quy trình so khớp mẫu tĩnh được tăng tốc bằng các đối tượng biểu thức chính quy được biên dịch trước (pre-compiled regex) từ thư viện `re` của Python.

### 3.3 Tầng 2: Tác tử AI Nhận thức LangGraph

Các luồng bất thường được leo thang sẽ được tiếp nhận bởi công cụ nhận thức Tầng 2, được mô hình hóa dưới dạng Đồ thị có hướng không chu trình (Directed Acyclic Graph) hoạt động như một Máy trạng thái hữu hạn (Finite State Machine - FSM) có trạng thái bằng cách sử dụng LangGraph [8]. Dữ liệu phiên và ngữ cảnh suy luận được lưu giữ bên trong một đối tượng trạng thái trung tâm, `SentinelState`. Quy trình làm việc của tác tử bao gồm ba nút chính: nút phân tích (analyze), nút truy xuất (retrieve), và nút giải quyết (resolve). Tại nút phân tích, tác tử đánh giá ngữ cảnh nhật ký được leo thang bằng cách sử dụng LLM lượng hóa cục bộ để phân loại rủi ro ban đầu. Nếu tác tử phát hiện sự thiếu hụt kiến thức chuyên môn (như một CVE chưa biết hoặc một chữ ký không quen thuộc), nó sẽ kích hoạt quá trình chuyển hướng điều kiện đến nút truy xuất. Tại nút truy xuất, hệ thống thực hiện truy vấn cơ sở tri thức lai kết hợp vector và từ khóa. Các trạng thái định tuyến và chuyển dịch được trình bày chi tiết trong Bảng 2.

Bảng 2. Ma trận chuyển trạng thái của FSM Tác tử Nhận thức Tầng 2.

| Trạng thái hiện tại | Đầu vào / Điều kiện               | Trạng thái tiếp theo | Hành động đầu ra                |
|---------------------|-----------------------------------|----------------------|---------------------------------|
| INIT                | Nhập cảnh báo                     | ANALYZE              | Tải ngữ cảnh phiên              |
| ANALYZE             | Độ tin cậy cao / Đe dọa đã biết   | RESOLVE              | Phân loại mối đe dọa            |
| ANALYZE             | Độ tin cậy thấp / Thiếu thông tin | RETRIEVE             | Câu truy vấn tìm kiếm           |
| RETRIEVE            | Tri thức đã được truy xuất        | ANALYZE              | Bổ sung ngữ cảnh vào Trạng thái |
| RESOLVE             | Độ tin cậy $\geq 0.7$             | EXECUTE              | Đề xuất phản hồi tương ứng      |
| RESOLVE             | Độ tin cậy $< 0.7$                | HITL                 | Leo thang tới Chuyên viên SOC   |

Sau khi quá trình truy xuất hoàn tất, luồng xử lý sẽ quay vòng lại nút phân tích để tái đánh giá các bản ghi nhật ký cùng với các thông tin ngữ cảnh được bổ sung. Chu kỳ lặp này giúp ngăn chặn hiện tượng ảo giác (hallucination) bằng cách ràng buộc suy luận của LLM dựa trên các tài liệu đã được xác thực. Khi độ tin cậy đạt đến ngưỡng quy định, tác tử chuyển sang nút giải quyết để tạo một cấu trúc dữ liệu JSON chi tiết chứa phân loại mối đe dọa, độ tin cậy và các quy tắc ngăn chặn được đề xuất. Nếu độ tin cậy dưới ngưỡng, tác tử sẽ định tuyến cảnh báo đến hàng đợi phê duyệt của con người (Human-in-the-Loop - HITL).

Hiện thực hóa kỹ thuật của đồ thị trạng thái sử dụng trình biên dịch của LangGraph. Trạng thái của tác tử được định nghĩa như một lớp tự điển có kiểu dữ liệu cấu trúc (typed dictionary), trong đó các trường lưu trữ khóa như chỉ số IOC và lịch sử quyết định được thiết lập ở chế độ chỉ cho phép ghi thêm (append-only) nhằm chống lại sự trôi dạt ngữ nghĩa (semantic drift) trong quá trình suy luận. Việc kết nối LLM được quản lý bởi lớp `OpenAILLMClient` giao tiếp với máy chủ llama.cpp chạy Gemma-2-9B-IT cục bộ, cấu hình với các tham số khắt khe như `temperature=0.0` và giới hạn cửa sổ ngữ cảnh để triệt tiêu tính bất định và ngăn chặn quá tải bộ nhớ VRAM.

3.4 Cơ chế Sinh Tăng cường Truy xuất Kép (Dual-RAG) và Bộ nhớ Ngữ nghĩa

Cơ chế Dual-RAG định hình các quyết định của tác tử bằng cách truy xuất ngữ cảnh từ hai cơ sở dữ liệu chuyên ngành thống nhất: cơ sở tri thức MITRE ATT&CK dùng để ánh xạ các

hành vi, chiến thuật và kỹ thuật đe dọa (TTPs), và kho lưu trữ kịch bản NIST SP 800-61r2 cung cấp các quy trình xử lý sự cố tiêu chuẩn [10]. Thay vì chỉ dựa vào khớp từ khóa đơn thuần hoặc các vector ngữ nghĩa dày đặc một cách độc lập [7], quá trình truy xuất sử dụng một chiến lược tìm kiếm lai (hybrid search). Bảng so sánh giữa các thành phần tìm kiếm dày đặc (dense) và thưa thớt (sparse) được chi tiết hóa trong Bảng 3.

Bảng 3. So sánh các mô hình truy xuất trong chiến lược tìm kiếm lai.

| Khía cạnh        | Tìm kiếm Vector Dày đặc (FAISS)                               | Tìm kiếm Từ khóa Thưa thớt (BM25)                             |
|------------------|---------------------------------------------------------------|---------------------------------------------------------------|
| Mô hình nền tảng | all-MiniLM-L6-v2 Embeddings                                   | Trọng số từ khóa BM25                                         |
| Logic so khớp    | Độ tương đồng Cosine ngữ nghĩa [18]                           | Tần suất từ - Tần suất nghịch đảo tài liệu (TF-IDF) [19]      |
| Ưu điểm          | Bắt được các từ đồng nghĩa, khái niệm và ngữ nghĩa trừu tượng | So khớp chính xác các định danh kỹ thuật (CVEs, IPs, số cổng) |
| Hạn chế          | Yếu khi khớp chính xác các từ khóa bám kỹ thuật               | Bị mù trước các từ đồng nghĩa ngữ nghĩa và ngữ cảnh khái niệm |

Điểm số từ các luồng xử lý dày đặc (FAISS) và thưa thớt (BM25) được tổng hợp lại bằng thuật toán Tổng hợp xếp hạng nghịch đảo (Reciprocal Rank Fusion - RRF) [11], tính toán một điểm số thống nhất  $R$  cho mỗi tài liệu  $d$  trên tập hợp các lượt tìm kiếm  $M$ :

$$R(d) = \sum_{m \in M} \frac{1}{k + r_m(d)} \quad (3.5)$$

trong đó  $r_m(d)$  là thứ hạng của tài liệu  $d$  trong lượt tìm kiếm  $m$ , và  $k$  là một hằng số tỷ lệ (thường chọn  $k = 60$ ). Để vượt qua nút thắt độ trễ của LLM, một mô-đun Bộ đệm Ngữ nghĩa (Semantic Cache) được triển khai phía trước tác tử. Bộ đệm này tính toán độ tương đồng Cosine giữa vector đặc trưng (embedding) của truy vấn mới và các thực thể truy vấn lịch sử. Nếu độ tương đồng vượt quá  $\theta \geq 0.95$ , hệ thống sẽ trả về ngay kết quả đã lưu trong bộ đệm, rút ngắn thời gian xử lý từ vài giây xuống còn mili giây. Bộ đệm này hoạt động dựa trên cơ chế LRU với cơ sở dữ liệu SQLite phụ trợ, giúp dữ liệu cache được bảo toàn ngay cả khi khởi động lại hệ thống.

3.5 Bộ nhớ Đe dọa và Liên kết Chiến dịch APT

Các tác nhân đe dọa tinh vi thường chia nhỏ chuỗi tấn công của chúng thành các sự kiện có mức độ nghiêm trọng thấp và phân tán trên các khoảng thời gian dài nhằm vượt qua các bộ lọc gói tin phi trạng thái. Để vạch trần các chiến dịch tấn công âm thầm và chậm rãi này [4], kiến trúc SENTINEL tích hợp một mô-đun Bộ nhớ Đe dọa (Threat Memory) bền vững, được triển khai dưới dạng cơ sở dữ liệu SQLite cục bộ. Mô-đun này được xây dựng trên các lược đồ (schema) chuyên dụng để theo dõi các cảnh báo lịch sử, điểm uy tín của các thực thể, và chuỗi tấn công theo thời gian. Chi tiết về các lược đồ cơ sở dữ liệu được trình bày trong Bảng 4.

Bảng 4. Thông số kỹ thuật lược đồ cơ sở dữ liệu Bộ nhớ Đe dọa.

| Tên bảng       | Trường khóa chính / thuộc tính                             | Mục đích chức năng                                                                              |
|----------------|------------------------------------------------------------|-------------------------------------------------------------------------------------------------|
| ip_reputation  | ip_address (PK), score, last_seen, status                  | Theo dõi điểm uy tín (0-100) và vòng đời hoạt động của các IP nguồn.                            |
| known_entities | entity_name (PK), ip_address, role                         | Khởi tạo trước các dịch vụ nội bộ đã được xác minh (như AD, DNS) để giảm thiểu cảnh báo giả.    |
| threat_events  | event_id (PK), ip_address, timestamp, alert_type, severity | Lưu trữ chuỗi các cảnh báo đã được leo thang theo trình tự thời gian phục vụ mục đích liên kết. |

Điểm uy tín của một địa chỉ IP sẽ tăng lên dựa trên mức độ nghiêm trọng của các cảnh báo mà nó kích hoạt, giới hạn tối đa là 100. Ngược lại, một hàm suy giảm (decay function) định kỳ chạy để giảm dần điểm uy tín của các IP không còn hoạt động:

$$S_{new} = S_{old} \times (1 - \lambda)^t \tag{3.6}$$

trong đó  $\lambda$  là tỷ lệ suy giảm và  $t$  là thời gian không hoạt động đã trôi qua. Thuật toán liên kết APT sẽ quét bảng threat\_events. Nếu phát hiện một IP nguồn kích hoạt các dị thường trong nhiều ngày khác nhau hoặc trên nhiều giai đoạn khác nhau của ma trận MITRE ATT&CK, hệ thống sẽ tự động nâng mức phân loại mỗi đe dọa lên nghiêm trọng cao, kích hoạt các biện pháp chặn phòng thủ. Tại mức cơ sở dữ liệu, các SQL triggers được thiết kế để tự động tính toán khoảng cách thời gian và điểm tích lũy của IP để tránh xử lý

dư thừa trên mã nguồn tác tử Python.

### 3.6 Tầng Rào chắn Bảo mật AI (Guardrails)

Do các LLM dễ bị tấn công chiếm quyền điều khiển chỉ thị (instruction hijacking / prompt injection), hệ thống SENTINEL triển khai một tầng Rào chắn Bảo mật AI (AI Security Guardrails) nhiều lớp nhằm cách ly công cụ suy luận khỏi các dữ liệu đầu vào không đáng tin cậy [9]. Cơ chế phòng thủ cốt lõi dựa trên kỹ thuật Đóng gói Dữ liệu Phân tách (Delimited Data Encapsulation). Đối với mỗi phiên làm việc, hệ thống tự động tạo ra một mã token thập lục phân ngẫu nhiên bảo mật bằng mật mã (ví dụ: <|DATA\_8F3E|>) bằng thư viện `os.urandom()`. Phần dữ liệu nhật ký thô chưa được kiểm chứng sẽ được bao bọc bên trong các thẻ phân tách này trong khuôn mẫu prompt, chỉ thị cho LLM rằng bất kỳ mã lệnh nào xuất hiện bên trong ranh giới này đều phải được xử lý nghiêm ngặt dưới dạng dữ liệu tĩnh thụ động thay vì các chỉ thị thực thi.

Để chống lại các cuộc tấn công Từ chối dịch vụ Token (Token DoS) và tràn ngữ cảnh, hệ thống tích hợp một trình Khai thác Mẫu Nhật ký (Log Template Miner) dựa trên thuật toán Drain3. Trình khai thác này nhóm các bản ghi nhật ký tương đồng thành các khuôn mẫu chung, loại bỏ các tham số ngẫu nhiên (chẳng hạn như mốc thời gian động hoặc ID luồng). Bộ Quản lý Ngân sách Token (Token Budget Manager) sau đó phân bổ tối đa 60% dung lượng ngữ cảnh cho các khuôn mẫu đã nén và 40% còn lại cho các điểm dị biệt có entropy cao. Cuối cùng, một Bộ lọc Làm sạch Đầu ra (Output Sanitization Filter) áp dụng cơ chế xác thực lược đồ JSON nghiêm ngặt, kiểm chứng câu trả lời của LLM chỉ chứa các trường được phép, đồng thời loại bỏ các thẻ hình ảnh markdown, kịch bản SVG, và các vector vượt rào mã hóa thập lục phân [12]. Lớp này được xây dựng dạng module độc lập `output_sanitizer` để lọc dữ liệu trước khi nạp vào SQLite hoặc giao diện dashboard.

### 3.7 Toàn vẹn Dữ liệu và Bảo vệ bằng Chuỗi HMAC

Để bảo vệ cơ sở dữ liệu nhật ký bảo mật trước các hành vi giả mạo bởi người nội bộ độc hại hoặc những kẻ tấn công giành được quyền truy cập vào hệ thống tệp tin, hệ thống triển khai kỹ thuật chuỗi liên kết log bằng HMAC (HMAC log chaining). Mỗi bản ghi nhật ký an ninh được liên kết mật mã với bản ghi liền trước nó, tạo thành một chuỗi vết kiểm toán tương tự cấu trúc blockchain nội bộ. Đối với bản ghi thứ  $i$ , mã băm bản ghi  $H_i$  được tính toán như sau:

$$H_i = \text{HMAC-SHA256}(D_i \parallel H_{i-1}, K) \quad (3.7)$$

trong đó  $D_i$  là dữ liệu tải tin của bản ghi hiện tại,  $H_{i-1}$  là mã băm của bản ghi liền trước, và  $K$  là khóa bí mật HMAC được lưu trữ an toàn. Nếu kẻ tấn công cố tình thay đổi nhật ký hoặc xóa một bản ghi, chuỗi băm sẽ bị đứt gãy và các quy trình kiểm tra xác thực chạy trên bảng điều khiển sẽ lập tức gắn cờ phát hiện hành vi giả mạo. Ngoài ra, hệ thống cũng bảo vệ cơ sở dữ liệu vector RAG trước các cuộc tấn công đầu độc ngữ nghĩa (semantic poisoning). Các tệp tin cơ sở dữ liệu vector được giám sát chặt chẽ bởi một trình quản lý mã checksum chuyên dụng thực hiện tính toán và so sánh giá trị băm SHA-256 của các tệp tin trước khi nạp chúng vào bộ nhớ, đảm bảo không có tài liệu độc hại nào bị tiêm vào bộ nhớ truy xuất của tác tử.

Các chức năng này được đóng gói trong các lớp `HMACHashing` và `ActionValidator`. Lớp `ActionValidator` chịu trách nhiệm kiểm tra dải IP an toàn (RFC1918) và phát hiện các siêu ký tự shell độc hại nhằm loại bỏ nguy cơ chèn lệnh hệ thống trong quá trình gọi kịch bản cấu hình tường lửa.

### 3.8 Giao diện Streamlit Bảng điều khiển Giám sát SOC (Streamlit UI)

Giao diện Bảng điều khiển Giám sát SOC được phát triển trên Streamlit, tuân thủ mô hình phản hồi (reactive model) liên lạc liên tục với backend và cơ sở dữ liệu SQLite. Streamlit UI tích hợp ba phân hệ chính: - **Phân hệ luồng và hàng đợi:** Hiển thị trực quan thông lượng log đi qua Tầng 1 và các kết quả phân tích phân loại của Tầng 2. - **Phân hệ phân tích bộ nhớ đe dọa:** Vẽ sơ đồ chuỗi lan truyền cảnh báo APT của các địa chỉ IP theo dòng thời gian. - **Phân hệ kiểm tra toàn vẹn log:** Liên tục xác thực chuỗi băm HMAC của cơ sở dữ liệu logs và đưa ra các đèn tín hiệu cảnh báo (Xanh: Toàn vẹn; Đỏ: Đã bị can thiệp/sửa đổi). Ngoài ra, giao diện hỗ trợ cơ chế phê duyệt HITL, cho phép phân tích viên kiểm tra các đề xuất của tác tử và nhấn nút đồng ý/hủy bỏ cập nhật cấu hình tường lửa thực tế.

### 3.9 Kiến trúc ảo hóa Docker và Triển khai hạ tầng

Hệ thống được đóng gói thông qua Docker với cấu hình `Dockerfile` đa tầng (multi-stage build) để tối ưu dung lượng ảnh sản phẩm. Trình biên dịch `llama.cpp` trong container được kích hoạt CUDA để tận dụng GPU của hệ thống vật lý giúp đẩy nhanh tốc độ suy luận của LLM. Tệp điều phối `docker-compose.yml` thiết lập mạng nội bộ liên kết container tác tử và container Streamlit, chia sẻ chung các phân vùng ổ đĩa (volume mounts) chứa cơ sở dữ liệu SQLite (`threat_memory.db` và `guardrails_audit.db`) để đảm bảo tính lưu trữ bền vững độc lập với vòng đời của các container.

### 3.10 Tóm tắt chương

Chương 3 đã xây dựng toàn diện thiết kế kiến trúc và quy trình triển khai kỹ thuật của hệ thống SENTINEL. Bằng cách gộp bộ lọc mạng tốc độ đường truyền phi trạng thái (Tầng 1) với tác tử suy luận nhận thức có trạng thái (Tầng 2), đồng thời bổ sung các rào chắn AI cùng cơ chế chữ ký HMAC, hệ thống đạt được hiệu năng cao và độ bảo mật tuyệt đối trước các tấn công đối kháng. Quy trình tự động hóa được kiểm soát an toàn bởi con người qua hàng đợi HITL trên Streamlit UI và được đóng gói hoàn chỉnh trong Docker. Chương 4 tiếp theo sẽ mô tả chi tiết các thiết lập thực nghiệm, nghiên cứu loại trừ (ablation study) và các báo cáo kiểm định thống kê đánh giá hiệu năng thực tế của hệ thống.

## Chương 4

### Thực nghiệm và Đánh giá

Chương này trình bày các minh chứng thực nghiệm của luận văn, kiểm chứng các giả thuyết nghiên cứu thông qua hệ thống chỉ số định lượng chặt chẽ. Hệ thống SENTINEL được đánh giá dựa trên khung đánh giá năm chiều (Chỉ số 5D: Độ chính xác, Hiệu suất, Bảo mật, Tính giải thích và Tính toàn vẹn). Nội dung chương nhấn mạnh thiết kế nghiên cứu loại trừ phân tầng (Ablation Study) và việc ứng dụng các mô hình thống kê sinh học (Kiểm định McNemar, Kiểm định Mann-Whitney U) để chứng minh rằng những cải tiến về mặt kiến trúc là có ý nghĩa thống kê và vững chắc về mặt toán học.

#### 4.1 Môi trường Thực nghiệm và Bộ Dữ liệu

Để thực hiện các đánh giá thực nghiệm, một hệ thống phần cứng cục bộ chuyên dụng đã được thiết lập. Cấu hình phần cứng bao gồm CPU Intel Core i9, 32GB RAM và GPU NVIDIA RTX 4060 Ti 16GB, được sử dụng để thực thi mô hình *Gemma-2-9B-IT* lượng tử hóa ở định dạng Q4\_K\_M. Quá trình thực nghiệm dựa trên hai bộ dữ liệu lớn: bộ dữ liệu CSE-CIC-IDS2018 bao gồm nhiều dạng tấn công mạng phổ biến như Brute Force, DoS và Web Attack làm cơ sở đánh giá độ chính xác tổng quát của phân loại; và bộ dữ liệu DAPT2020 được sử dụng để kiểm thử khả năng liên kết chuỗi tấn công APT đa giai đoạn diễn ra trong thời gian dài. Để mô phỏng chân thực môi trường SIEM thực tế, một bộ giả lập luồng dữ liệu Unified Stream được lập trình để trộn và phát lại các dòng log theo đúng mốc thời gian ảo, chuyển giao dữ liệu trực tiếp tới hàng đợi phát hiện của hệ thống.

#### 4.2 Chỉ số Đánh giá 5D và Thiết kế Nghiên cứu Loại trừ (Ablation Study)

Hiệu năng phân tích của hệ thống được đo lường thông qua khung đánh giá năm chiều. Các chỉ số 5D bao gồm Độ chính xác (đo bằng F1-Score, Precision, Recall), Hiệu suất (đo bằng độ trễ và băng thông xử lý), Bảo mật (độ hiệu quả ngăn chặn tấn công đối kháng), Tính

giải thích (đánh giá mức độ chi tiết của báo cáo pháp y) và Tính toàn vẹn (xác thực tính toàn vẹn qua chuỗi HMAC). Nhằm tách biệt và làm rõ đóng góp định lượng của từng cấu phần đề xuất, nghiên cứu thiết lập 6 cấu hình thử nghiệm loại trừ. Cấu hình A đóng vai trò là baseline thứ nhất, chỉ sử dụng bộ lọc luật tính truyền thống. Cấu hình B đóng vai trò là baseline thứ hai, sử dụng trực tiếp LLM cục bộ mà không qua bộ lọc Welford hay hệ thống RAG hỗ trợ. Cấu hình C giới thiệu bộ lọc Welford Tầng 1 trước khi gửi đến LLM. Cấu hình D bổ sung hệ thống RAG vector đơn lẻ (FAISS) kết hợp với LLM. Cấu hình E mở rộng hệ RAG thành tìm kiếm lai kết hợp FAISS và BM25. Cuối cùng, Cấu hình F đại diện cho hệ thống SENTINEL hoàn chỉnh, kết hợp đồng bộ bộ lọc Welford Tầng 1, tác tử LangGraph Tầng 2, hệ RAG kép và các rào chắn bảo mật.

### 4.3 Đánh giá Độ chính xác và Kiểm định Thống kê McNemar

Kết quả đánh giá độ chính xác cho thấy sự cải thiện vượt trội về Precision, Recall và F1-Score giữa các cấu hình thử nghiệm. Đáng chú ý nhất, Cấu hình F hoàn chỉnh đạt được sự cân bằng tối ưu về chỉ số F1 nhờ loại bỏ hiệu quả lượng lớn các cảnh báo dương tính giả từ bộ lọc tĩnh, đồng thời tăng cường tỷ lệ phát hiện các mối đe dọa Zero-day. Khả năng phát hiện APT được chứng minh khi bộ lọc Welford Tầng 1 bắt được các dấu hiệu bất thường nhỏ lẻ để kích hoạt chuỗi phân tích trong Bộ nhớ Đe dọa của tác tử nhằm vạch trần hành vi di chuyển ngang. Để chứng minh tính ý nghĩa khoa học của sự cải thiện này, kiểm định McNemar đã được áp dụng để so sánh ma trận nhầm lẫn (Confusion Matrix) giữa baseline Cấu hình B và Cấu hình F. Kết quả tính toán cho ra giá trị  $p\text{-value} < 0.05$ , bác bỏ giả thuyết không (Null Hypothesis) và khẳng định sự cải thiện hiệu năng là do ưu thế vượt trội của kiến trúc SENTINEL chứ không phải do yếu tố ngẫu nhiên.

### 4.4 Đánh giá Độ trễ Hiệu suất và Kiểm định Mann-Whitney U

Đánh giá hiệu suất tập trung vào đo lường độ trễ xử lý đầu cuối trên mỗi luồng dữ liệu đo lường mạng. Việc tích hợp bộ lọc Welford Tầng 1 giúp giải phóng phần lớn băng thông nhờ xử lý các log mạng lành tính trong thời gian cố định  $O(1)$ , trong khi bộ đệm ngữ nghĩa chặn lọc thành công các truy vấn lặp lại, rút ngắn độ trễ quyết định của LLM từ hàng giây xuống còn mức mili-giây. Để chứng minh ý nghĩa khoa học của cơ chế giảm tải này, kiểm định phi tham số Mann-Whitney U được thực hiện để so sánh phân phối độ trễ. Kết quả kiểm định chứng minh rằng luồng xử lý của SENTINEL nhanh hơn một cách có ý nghĩa thống kê ( $p\text{-value} < 0.05$ ) so với việc gửi trực tiếp toàn bộ log thô tới LLM, khẳng định tính khả thi của hệ thống trong môi trường vận hành thời gian thực.

## 4.5 Đánh giá Năng lực Phòng thủ Đối kháng (Bảo mật)

Để đánh giá mức độ an toàn của tầng nhận thức, một bộ dữ liệu kiểm thử tấn công đối kháng gồm 45 tải trọng độc hại chuyên dụng đã được biên soạn. Các kịch bản này giả lập các kỹ thuật tiêm prompt trực tiếp, ngụy trang mã hóa và buôn lậu dấu phân tách nhằm mục đích chiếm quyền điều khiển suy luận của tác tử (ví dụ: ra lệnh cho LLM bỏ qua các chính sách bảo mật và gắn nhãn an toàn cho một IP độc hại). Kết quả đo lường tỷ lệ ngăn chặn cho thấy sự tương phản rõ rệt: cấu hình không được bảo vệ chịu tỷ lệ tấn công thành công lên tới 80%, trong khi cấu hình tích hợp rào chắn Đóng gói Dữ liệu Phân tách của SENTINEL đã ngăn chặn hoàn toàn các tải trọng đối kháng, đạt được tỷ lệ phòng thủ tuyệt đối.

## 4.6 Đánh giá Toàn vẹn Dữ liệu và Chất lượng RAG qua mô hình LLM Trọng tài

Giai đoạn xác thực cuối cùng tập trung đánh giá tính toàn vẹn của cơ sở dữ liệu và chất lượng truy xuất tri thức. Để kiểm tra tính toàn vẹn của lịch sử kiểm toán, một kịch bản tấn công giả định đã được thực hiện bằng cách cố tình sửa đổi nhãn log trong cơ sở dữ liệu. Hàm xác thực chuỗi log HMAC đã ngay lập tức phát hiện sự không trùng khớp về chữ ký và đưa ra cảnh báo chuỗi log bị can thiệp trên bảng điều khiển. Để đánh giá chất lượng RAG, khung đánh giá RAGAS được triển khai với mô hình Llama-3.1 bên ngoài đóng vai trò là trọng tài độc lập để chấm điểm quy trình truy xuất theo bốn tiêu chí cốt lõi bao gồm Context Precision, Context Recall, Faithfulness và Answer Relevancy. Kết quả chấm điểm khẳng định cấu hình Dual-RAG kết hợp thuật toán RRF vượt trội hơn hẳn so với tìm kiếm vector đơn lẻ, cung cấp ngữ cảnh chính xác và đáng tin cậy giúp triệt tiêu hoàn toàn ảo giác thông tin của LLM.

Tóm lại, Chương 4 đã chứng minh tính ưu việt về mặt kỹ thuật của SENTINEL thông qua các dữ liệu thực nghiệm định lượng rõ ràng cùng các kiểm định thống kê sinh học chặt chẽ. Chương 5 sẽ đúc rút ý nghĩa khoa học của các phát hiện này và định hình hướng phát triển tương lai cho hệ thống.

## Chương 5

### Kết luận và Hướng phát triển

Chương kết luận này tổng hợp lại toàn bộ hành trình nghiên cứu của luận văn với đề tài ”Kiến trúc nhận thức hai tầng tự động hóa phát hiện đe dọa và phản hồi sự cố sử dụng AI tác tử” (SENTINEL). Chương này đúc rút các kết quả nghiên cứu đã được thực nghiệm chứng minh, tự đánh giá các giới hạn trong khuôn khổ một luận văn thạc sĩ và mở ra những chân trời mới cho nghiên cứu an ninh mạng tích hợp trí tuệ nhân tạo.

#### 5.1 Tổng hợp Kết quả Nghiên cứu Đạt được

Tổng hợp kết quả nghiên cứu đạt được khẳng định sự giải quyết thành công các câu hỏi nghiên cứu cốt lõi. Cụ thể, kiến trúc phân tầng kết hợp giữa bộ lọc Welford Tầng 1 và Tác tử LangGraph Tầng 2 đã loại bỏ hiệu quả nút thắt cổ chai về độ trễ và nạn bội thực cảnh báo vốn gây tê liệt các quy trình SOC truyền thống. Về khía cạnh an ninh hệ thống AI, các đánh giá thực nghiệm đã chứng minh tính khả thi của phương pháp Đóng gói Dữ liệu Phân tách và liên kết chuỗi log HMAC trong việc ngăn ngừa các nguy cơ thao túng đối kháng—bao gồm tiêm prompt, buôn lậu dấu phân tách và thay đổi dữ liệu—nhắm vào các hệ suy luận nội bộ của doanh nghiệp. Hơn nữa, hệ thống đã vượt qua các thách thức về Zero-day và chiến dịch APT nhờ sự phối hợp chặt chẽ giữa tính năng theo vết uy tín trong Bộ nhớ Đe dọa và cơ sở tri thức kép Dual-RAG. Cơ chế này cung cấp cho tác tử nhận thức ngữ cảnh sâu sắc để vạch trần các chiến dịch thâm nhập đa giai đoạn tinh vi. Cuối cùng, tính khoa học chặt chẽ của các phát hiện này được đảm bảo vững chắc qua các đánh giá 5D thực nghiệm và các kiểm định thống kê chuẩn mực như McNemar và Mann-Whitney U.

#### 5.2 Đóng góp Khoa học và Thực tiễn

Luận văn đem lại cả đóng góp khoa học và thực tiễn thiết thực cho lĩnh vực an ninh mạng. Về mặt giá trị khoa học, nghiên cứu cung cấp một khung kiến trúc module hóa cao để tích hợp toán học thống kê với các mô hình ngôn ngữ lớn trong an ninh mạng, làm giàu thêm

kho tàng lý thuyết liên quan đến bảo mật nhận thức LLM, rào chắn bảo mật và cô lập ngữ cảnh. Về mặt thực tiễn, sản phẩm SENTINEL hoàn thiện đóng vai trò là một công cụ hỗ trợ độc lập hoặc hạt nhân xử lý cho các doanh nghiệp vừa và nhỏ (SMBs) thiếu ngân sách duy trì đội ngũ phân tích SOC Tier-1 quy mô lớn. Nhờ vận hành hoàn toàn ngoại tuyến (offline), hệ thống bảo toàn tuyệt đối chủ quyền dữ liệu và tuân thủ chặt chẽ nguyên lý an ninh Zero Trust.

### 5.3 Các Giới hạn Hiện tại

Mặc dù hệ thống đã chứng minh tính ưu việt rõ rệt, nghiên cứu vẫn thẳng thắn thừa nhận các giới hạn kỹ thuật phân định phạm vi hoạt động. Về định dạng dữ liệu đầu vào, hệ thống hiện mới chỉ kiểm thử sâu trên các log luồng mạng (Network Flow) và tải trọng HTTP, trong khi môi trường doanh nghiệp thực tế đòi hỏi khả năng xử lý các định dạng log phi cấu trúc đa dạng hơn như Windows Event Logs, Linux Syslogs và CloudTrail, đòi hỏi các bộ tiền xử lý ngữ nghĩa phức tạp hơn. Về mặt phần cứng, dù độ trễ đã được cải thiện đáng kể nhờ bộ đệm ngữ nghĩa, việc xử lý các cảnh báo hoàn toàn mới vẫn yêu cầu chu kỳ suy luận lớn từ LLM, đặt ra yêu cầu chi phí đầu tư hạ tầng GPU chuyên dụng tương đối lớn nếu vận hành ở quy mô băng thông mạng hàng trăm Gigabit/giây. Cuối cùng, về mặt phản hồi vật lý, nghiên cứu chủ động giới hạn hành động của tác tử ở mức đề xuất (chẳng hạn như khuyến nghị quy tắc tường lửa) thay vì tự động cấu hình chặn vật lý trên thiết bị định tuyến. Dù giúp ngăn ngừa rủi ro tự từ chối dịch vụ (Self-DoS), thiết lập này làm hạn chế khả năng chặn thời gian thực hoàn toàn tự động của hệ thống.

### 5.4 Hướng Phát triển Tương lai

Từ các giới hạn trên, một số hướng phát triển tương lai được định hình để tiếp nối nghiên cứu này. Thứ nhất, việc tích hợp học liên hợp (Federated Learning) có thể mở rộng SENTINEL thành một kiến trúc phi tập trung, cho phép các đầu cuối SOC chia sẻ các tham số mô hình đã học về biến thể mã độc mới mà không cần truyền tải các log thô nhạy cảm vi phạm quyền riêng tư. Thứ hai, mô hình tác tử LangGraph đơn khối có thể phân tách thành hệ thống đa tác tử (Multi-Agent System - MAS) gồm các tác tử chuyên biệt như phân tích mã độc, phân tích mạng và tình báo mối đe dọa để cùng tranh luận trước khi đưa ra phán quyết cuối cùng nhằm tối ưu hóa độ chính xác. Thứ ba, năng lực bảo mật của hệ thống có thể được củng cố bằng cách xây dựng một tác tử thử nghiệm xâm nhập tự động (Red Team Agent) để liên tục tạo ra các tải trọng đối kháng tinh vi tấn công Sentinel, qua đó tự đánh giá và tự động nâng cấp khả năng phòng thủ của hệ thống.

*Khép lại một nỗ lực khiêm tốn, nhưng mở ra những khát vọng sâu sắc trong hành trình bảo vệ không gian số bằng sức mạnh của AI Tác tử.*

## Tài liệu tham khảo

- [1] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward Generating a New Dataset for Cyber Security in Ad hoc Networks,” in *Proceedings of the International Conference on Information Systems Security and Privacy (ICISSP)*, 2018.
- [2] A. Alsubaei, A. Abuhussein, and S. Shiva, “Security Information and Event Management (SIEM) Features, Challenges, and Solutions,” *IEEE Access*, vol. 9, pp. 121111–121128, 2021.
- [3] P. M. M. S. Silva *et al.*, “The Big Data Security Challenges in the Era of Cloud Computing,” *Computer Networks*, vol. 156, pp. 102–115, 2019.
- [4] M. Alshamrani *et al.*, “A Survey on Advanced Persistent Threats: Techniques, Solutions, Challenges, and Research Opportunities,” *IEEE Communications Surveys & Tutorials*, vol. 21, no. 2, pp. 1851–1877, 2021.
- [5] S. Hassan, M. A. Saleem, and O. E. Ogu, “Alert Fatigue in Cybersecurity: A Review,” *IEEE Access*, vol. 10, pp. 58632–58645, 2022.
- [6] B. P. Welford, “Note on a Method for Calculating Corrected Sums of Squares and Products,” *Technometrics*, vol. 4, no. 3, pp. 419–420, 1962.
- [7] P. Lewis *et al.*, “Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks,” *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 33, pp. 9459–9474, 2020.
- [8] LangChain AI, “LangGraph: Multi-Actor, Stateful LLM Applications,” *GitHub repository*, 2024. [Online]. Available: <https://github.com/langchain-ai/langgraph>
- [9] K. Greshake, S. Abdelnabi, S. Mishra, A. Endres, T. Holz, and M. Fritz, “More than you’ve asked for: A Comprehensive Analysis of Novel Prompt Injection Threats to Application-Integrated Large Language Models,” *arXiv preprint arXiv:2302.12173*, 2023.
- [10] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, “Computer Security Incident Handling Guide,” NIST Special Publication 800-61 Revision 2, 2012.
- [11] G. V. Cormack, C. L. A. Clarke, and S. Buettcher, “Reciprocal Rank Fusion Outperforms Condorcet and Individual Bootstrap Product Algorithms,” in *Proceedings of the 32nd International ACM SIGIR Conference on Research and Development in Information Retrieval*, 2009.

- [12] T. Ravindran *et al.*, “Poisoning the Watchtower: Prompt Injection Attacks Against LLM-Augmented Security Operations Through Adversarial Log Content,” *arXiv preprint arXiv:2605.24421*, 2026.
- [13] A. Researcher *et al.*, “CyberRAG: An Agentic RAG cyber attack classification and reporting tool,” *Future Generation Computer Systems*, vol. 176, p. 108186, 2026.
- [14] A. Abdennebi *et al.*, “LanG – A Governance-Aware Agentic AI Platform for Unified Security Operations,” *arXiv preprint arXiv:2604.05440*, 2026.
- [15] M. Analyst *et al.*, “Policy-Guided Threat Hunting: An LLM enabled Framework with Splunk SOC Triage,” *arXiv preprint arXiv:2603.23966*, 2026.
- [16] A. Vaswani *et al.*, “Attention is All You Need,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 30, pp. 5998–6008, 2017.
- [17] A. Gholami *et al.*, “A Survey of Quantization Methods for Efficient Neural Network Inference,” *arXiv preprint arXiv:2103.13630*, 2021.
- [18] J. Johnson, M. Douze, and H. Jégou, “Billion-Scale Similarity Search with GPUs,” *IEEE Transactions on Big Data*, vol. 7, no. 3, pp. 535–547, 2019.
- [19] S. Robertson and H. Zaragoza, “The Probabilistic Relevance Framework: BM25 and Beyond,” *Foundations and Trends in Information Retrieval*, vol. 3, no. 4, pp. 333–380, 2009.